

제정 2008. 5. 2. 국민권익위원회훈령 제15호
 일부개정 2009. 6. 3. 국민권익위원회훈령 제39호
 일부개정 2010. 4. 5. 국민권익위원회훈령 제54호
 일부개정 2010. 7. 19. 국민권익위원회훈령 제59호
 일부개정 2012. 10. 25. 국민권익위원회훈령 제81호
 일부개정 2013. 6. 21. 국민권익위원회훈령 제91호
 전부개정 2015. 11. 16. 국민권익위원회훈령 제116호
 일부개정 2017. 12. 29. 국민권익위원회훈령 제143호
 일부개정 2018. 8. 7. 국민권익위원회훈령 제156호
 일부개정 2019. 6. 13. 국민권익위원회훈령 제180호
 일부개정 2020. 8. 31. 국민권익위원회훈령 제233호

「국민권익위원회 정보보호 규정」

2020. 8.

목 차

제1장 총칙	1
제1조(목적)	1
제2조(적용범위 및 대상)	1
제3조(정의)	1
제2장 기본활동 및 업무수행	4
제4조(정보보안 기본활동)	4
제5조(정보보안책임관 · 정보보안담당관 운영)	4
제6조(분임정보보안담당관 운용)	5
제7조(정보보호실무협의회 운영)	5
제8조(정보보안 규정관리)	6
제9조(세부추진계획 수립 및 심사분석)	6
제10조(정보보안 교육)	6
제11조(감사 계획수립)	7
제12조(감사 전담반 구성)	7
제13조(정보보안 감사)	7
제14조(지도방문)	8
제15조(보안관리 실태평가)	8
제16조(무선도청 탐지)	8
제17조(사이버보안진단의 날)	9
제18조(유관기관과의 협조)	9
제3장 요소별 보안관리	9
제1절 정보통신 기반 보안관리	9
제19조(정보통신망 보안관리)	9
제20조(우회 정보통신망 보안관리)	11
제21조(정보시스템 보안관리)	11

제22조(비밀의 전자적 처리)	13
제23조(웹서버 등 공개서버 보안관리)	13
제24조(영상회의시스템 보안관리)	14
제25조(모바일 및 사물인터넷 장비 보안관리)	14
제26조(클라우드 시스템 보안관리)	15
제27조(사용자계정 관리)	15
제28조(비밀번호 관리)	16
제29조(업무망 보안관리)	17
제30조(네트워크장비 보안관리)	17
제31조(이동통신망 보안관리)	18
제32조(무선랜 보안관리)	18
제33조(인터넷전화 보안관리)	19
제34조(원격접속 보안)	20
제2절 인적 보안관리	21
제35조(인적보안)	21
제36조(업무대행자 보안관리)	21
제3절 PC 보안관리	22
제37조(PC 관리책임)	22
제38조(PC 보안설정)	22
제39조(인터넷PC 보안관리)	23
제40조(PC 하드웨어 관리)	23
제41조(소프트웨어 설치제한)	24
제42조(공유폴더 관리)	24
제43조(PC 정보보안 사고 대응)	24
제44조(유지보수 보안)	25
제4절 전자우편 및 인터넷 사용보안	25

제45조(전자우편 보안)	25
제46조(인터넷 사용 보안)	25
제47조(악성코드 감염 방지대책)	26

제5절 전자정보 보안관리	27
제48조(전자정보 보안조치)	27
제49조(일반 전자정보 보호등급 분류)	28
제50조(정보자산의 분류 주기)	28
제51조(전산자료 보안관리)	29
제51조의2(비공개 업무자료 처리)	29
제52조(전자정보 저장매체 불용처리)	30
제53조(서버 보안관리)	31
제54조(홈페이지 게시자료 보안관리)	31
제55조(저장매체 보안관리)	32
제56조(휴대용 저장매체 보안관리)	33
제57조(백업관리)	33
제58조(접근기록 관리)	34

제4장 정보통신실 보안	34
제59조(주요 정보통신 기반시설 등의 보호구역 설정)	34
제60조(정보통신실 출입통제 절차)	35
제61조(장비 반출입 통제)	35
제62조(일상점검)	36
제63조(예방정비)	36
제64조(환경보안)	36

제5장 정보화용역사업 보안관리	37
제65조(용역사업 보안관리)	37
제66조(계약 시 유의사항)	38
제66조의2(계약 특수조건)	39

제67조(작업환경 구성)	40
제67조의2(원격지 개발보안)	40
제68조(내부시스템 접근통제)	40
제69조(시스템 사용 모니터링)	41
제70조(자료유출 방지)	41
제6장 안전성 확인	42
제1절 보안성 검토	42
제71조(정보시스템 도입·구축 시 인가 기준)	42
제72조(보안성 검토 신청)	42
제73조(보안성 검토 절차)	45
제74조(제출 문서)	45
제75조(결과 조치)	45
제2절 보안적합성 검증	46
제76조(정보보호시스템의 도입 등)	46
제77조(보안적합성 검증 신청)	46
제78조(신청서류)	47
제79조(검증시험 및 결과조치)	48
제80조(사후 관리)	48
제81조(무단변경 및 오용금지)	49
제7장 사이버위협 탐지·대응 및 재난복구 대책	49
제82조(침해사고 대응체계 구축)	49
제83조(침해사고 초동조치)	49
제84조(사고통보 및 복구)	49
제85조(재난복구 대책)	50
제86조(모의훈련)	50

제8장 사고처리	51
제87조(정보보안 사고조사)	51
제88조(보안 규정 위반자 처벌)	51
부칙	51
별표	52
[별표 1] 교육대상자 별 교육내용	53
[별표 2] 정보보안 점검표	54
[별표 3] PC 보안 설정	60
[별표 4] 저장매체 자료 삭제 방법	61
[별표 5] 시설 보안	62
[별표 6] 정보자산 분류	63
[별표 7] 정보보안 사고 유형	65
[별표 8] 정보화 용역사업자 보안위규 처리기준	66
[별표 9] 정보화 용역사업자 보안 위약금 부과기준	69
[별표 10] 정보보호시스템 유형별 도입요건	70
[별표 11] 정보보안 위규자 처리규정	71
별지 서식	72
[별지 제1호 서식] 정보보안업무 세부 추진계획	73
[별지 제2호 서식] 정보시스템 관리대장	74
[별지 제3호 서식] 보안·비밀유지서약서	75
[별지 제4호 서식] 정보보호시스템 도입시 확인사항	77
[별지 제5호 서식] 보안적합성 검증 신청서	78
[별지 제6호 서식] 정보보호시스템 운용현황	79
[별지 제7호 서식] 사용자 계정 관리대장	80
[별지 제8호 서식] 정보자산 보안등급표	80
[별지 제9호 서식] 무선랜 점검기록부	81

[별지 제10호 서식] 무선랜 점검항목 확인대장	82
[별지 제11호 서식] 무선랜 장비 관리대장	83
[별지 제12호 서식] 정보시스템 보안취약점 점검표	84
[별지 제13호 서식] 자료 반·출입 보안조치 관리대장	86
[별지 제14호 서식] 시스템 계정 신청서	87
[별지 제15호 서식] 네트워크 보안정책 설정 신청서	88
[별지 제16호 서식] 정보보안 사고 신고서	89
[별지 제17호 서식] 저장매체 자료 삭제 확인서	90
[별지 제18호 서식] 보안확약서	91
[별지 제19호 서식] 백업 관리대장	92
[별지 제20호 서식] 정보시스템 서비스 포트 관리대장	93
[별지 제21호 서식] PC·노트북 관리대장	94
[별지 제22호 서식] 정보통신실 상시 출입자 명단	95
[별지 제23호 서식] 정보통신실 출입자 관리대장	96
[별지 제24호 서식] 정보보호시스템 보안기능 점검표	97
[별지 제25호 서식] 정보보안시스템 운영 점검사항	100
[별지 제26호 서식] 네트워크 장비 보안적합성 검증 신청서	102
[별지 제27호 서식] 네트워크 장비 도입 최소 보안 요구사항	103
[별지 제28호 서식] 네트워크 변경내용 분석서	105
[별지 제29호 서식] 정보보호시스템 도입 확인서	107

부록 108

[부록 1] USB 메모리 등 휴대용 저장매체 보안관리지침	109
--	-----

제1장 총칙

제1조(목적) 이 규정은 「보안업무규정」(대통령령), 「국가사이버안전관리규정」(대통령훈령), 「국가위기관리기본지침」(대통령령) 및 「전자정부법」과 같은 법 시행령, 「정보통신기반보호법」과 같은 법 시행령, 「국가정보보안기본지침」 등에 따라 국가 정보보안을 위하여 **국민권익위원회 본부 및 소속기관 (이하 "위원회"라 한다)**이 수행해야 할 기본활동을 규정함을 목적으로 한다.

제2조(적용범위 및 대상) ① 이 규정은 본부와 그 소속기관에 적용한다.

② 정보보안업무에 관하여 「**국가정보보안기본지침**」과 「**국민권익위원회 보안업무 규정 시행세칙**」 등 다른 법령 또는 규정에 따로 정함이 있는 것을 제외하고는 이 규정에서 정하는 바에 따른다.

제3조(정의) 이 규정에서 사용하는 용어의 정의는 다음과 같다.

1. "정보보안" 또는 "정보보호"라 함은 정보통신 수단으로 수집, 가공, 저장, 검색, 송수신되는 정보의 유출, 위변조, 훼손 등을 방지하거나 정보통신망을 보호하기 위하여 관리적, 물리적, 기술적 수단을 강구하는 일체의 행위를 말한다.
2. "사용자"라 함은 정보보안담당관으로부터 정보통신망 또는 정보시스템에 대한 접근 또는 사용 허가를 받은 **위원회 소속** 공무원 등을 말한다.
3. "정보통신망"이라 함은 유·무선, 광선, 위성 등을 매개로 하는 다양한 정보통신 수단에 의하여 부호, 문자, 음성, 영상 등의 정보를 수집·가공·저장·검색·송수신하는 정보통신체제를 말한다.
4. "정보통신실"이라 함은 전산장비(서버·PC 등), 전송장비(교환기 등), 통신장비(라우터 등), 보안장비(방화벽 등) 등 정보통신망과 정보시스템 및 보안시스템이 종합적으로 설치·운용되는 장소를 말한다.
5. "인터넷서비스망"(이하 "인터넷망"이라 한다)이라 함은 위원회 네트워크 중에서 인터넷을 사용할 수 있도록 연결되어 있는 인터넷 전용망을 말한다.
6. "업무전산망"(이하 "업무망"이라 한다)이라 함은 위원회 네트워크 중에서 내부

- 업무를 수행할 수 있도록 연결되어 있는 내부 전산망을 말한다.
7. "전산자료"라 함은 전산장비에 의하여 전자기적인 형태로 입력·보관되어 있는 각종 자료(data)를 말하며, 그 자료가 입력되어 있는 보조기억매체를 포함한다.
 8. "휴대용저장매체"라 함은 USB메모리, 플래시메모리, CD(Compact Disk), VD(Digital Versatile Disk), IC칩 등 정보를 저장할 수 있는 일체의 것으로 PC 등의 정보시스템과 분리할 수 있는 기억장치를 말한다.
 9. "사이버공격"이라 함은 해킹·컴퓨터바이러스·논리폭탄·메일폭탄·서비스방해 등 전자적 수단에 의하여 국가정보통신망을 불법침입·교란·마비·파괴하거나 정보를 절취·훼손하는 일체의 공격행위를 말한다.
 10. "암호모듈"이라 함은 정보의 유출, 위·변조, 훼손 등을 방지하기 위해 암호논리를 활용하여 구현한 수단이나 도구를 말한다.
 11. "암호장비"라 함은 정보통신 수단으로 처리·저장·송수신 되는 정보를 보호할 목적으로 암호논리를 내장하여 제작된 장비나 장치를 말한다.
 12. "정보시스템"이라 함은 서버, PC 등 단말기, 보조기억매체, 네트워크 장치, 응용 프로그램 등 정보의 수집·가공·저장·검색·송수신에 필요한 하드웨어 및 소프트웨어 일체를 말한다.
 13. "보호구역"이라 함은 출입자 통제 등 철저한 보안대책이 요구되는 구역을 말한다.
 14. "진단도구"라 함은 정보통신망과 정보시스템 및 보안시스템에 대한 보안 취약점을 분석하고 점검할 수 있는 기술이나 장치를 말한다.
 15. "완전포맷"이라 함은 저장매체 전체의 자료저장 위치에 새로운 자료(0 또는 1)를 중복하여 저장하는 것을 말한다.
 16. "안전측정"이라 함은 정보통신망을 불법침입·교란·마비·파괴하거나 정보를 절취·훼손하는 해킹·컴퓨터바이러스·서비스방해·도청 등으로부터 정보통신망과 정보를 보호하기 위하여 정보보안 취약점을 진단하는 제반활동을 말한다.
 17. "전자정보"라 함은 위원회가 업무와 관련하여 취급하는 전자문서 및 전자기록물을 말한다.
 18. "전자기록물"이라 함은 정보처리능력을 가진 장치에 의하여 전자적인 형태로

- 송·수신 또는 저장되는 기록정보자료를 말한다.
19. "전자문서"라 함은 컴퓨터 등 정보처리 능력을 가진 장치에 의하여 전자적인 형태로 송·수신 또는 저장되는 정보를 말한다.
 20. "정보보호시스템"이라 함은 정보의 수집·저장·검색·송신·수신 시 정보의 유출, 위·변조, 훼손 등을 방지하기 위한 하드웨어 및 소프트웨어를 말한다.
 21. "무선도청 탐지"라 함은 유·무선 도청탐지장비 등을 이용하여 은닉된 무선도청장치 색출과 각종 도청 위해요소를 제거하는 제반활동을 말한다.
 22. "업무자료"라 함은 다음 각 목의 어느 하나에 해당하는 것을 말한다.
 - 가. 「전자정부법」 제2조제6호에 따른 행정정보 및 같은 법 제2조제7호에 따른 전자문서
 - 나. 「공공기록물 관리에 관한 법률 시행령」 제2조제2호에 따른 전자기록물
 - 다. 기타 다른 법령에 의하여 공무원등이 직무상 작성·취득하였거나 보유·관리하는 자료로서 전자적으로 처리되어 부호·문자·음성·음향·영상 등으로 표현된 것
 23. "비밀"이라 함은 업무자료 중에서 「보안업무규정」 제4조에 따라 분류된 비밀을 말한다.
 24. "대외비"라 함은 업무자료 중에서 「보안업무규정」 제16조제3항에 따라 분류된 대외비를 말한다.
 25. "비공개 업무자료"라 함은 비밀 및 대외비를 제외한 업무자료 중에서 다음 각 목의 어느 하나에 해당하는 자료 또는 정보를 말한다.
 - 가. 「공공기관의 정보공개에 관한 법률」 제9조제1항에 따른 비공개 대상 정보
 - 나. 국회 소속 공무원(「국회의원수당 등에 관한 법률」 제9조에 따른 보좌직원을 포함한다) 또는 「지방자치법」 제30조에 따른 지방의회 소속공무원의 직무상 요구에 따라 작성 또는 취득한 자료
 - 다. 가목에 따른 비공개 대상 정보의 주요 내용이 기술된 문장 또는 문구
 26. "공개 업무자료"라 함은 업무자료 중에서 비밀 및 대외비와 비공개 업무자료를 제외한 모든 자료 또는 정보를 말한다.

제2장 기본활동 및 업무수행

제4조(정보보안 기본활동) 국민권익위원회 위원장(이하 "위원장"이라 한다)은 정보통신 수단에 의한 각종 정보의 누설(漏泄)을 방지하고 보호하여야 하며 다음 각 호의 정보보안 기본활동을 수행하여야 한다.

1. 정보보안 정책 및 기본계획 수립·시행
2. 정보보안 관련 규정·지침 등 제·개정
3. 정보보안 업무 지도·감독
4. 정보보안 감사 및 심사분석
5. 정보보안 관리실태 평가
6. 사이버공격 초동조치 및 대응
7. 사이버위협정보 수집·분석 및 보안관계
8. 정보보안 예산 및 전문 인력 확보
9. 정보보안 사고조사 결과 처리
10. 정보보안 교육 및 정보협력
11. 도청(盜聽) 위해(危害)요소 제거
12. 주요 정보통신 기반시설 보호활동
13. 정보통신망 보안대책의 수립·시행
14. 사이버보안진단의 날 계획 수립·시행
15. 기타 정보보안 관련 사항

제5조(정보보안책임관·정보보안담당관 운영) ① 위원장은 제4조에 따른 정보보안 기본활동의 효율적인 수행을 위하여 정보보안 업무를 총괄하는 정보보안책임관과 정보보안담당관을 임명하여야 한다.

- ② 기획조정실장이 발령과 동시에 위원회 정보보안책임관이 된다.
- ③ 혁신행정담당관이 발령과 동시에 위원회 정보보안담당관이 된다.
- ④ 정보보안담당관은 제4조 각 호에 해당하는 업무를 수행함에 있어 필요한 경우 해당 업무의 일부를 분임정보보안담당관에게 위임할 수 있다.

제6조(분임정보보안담당관 운영) ① 정보보안책임관은 정보통신망을 구성하거나 이에 기반을 둔 각종 업무처리시스템의 정보보안을 위하여 정보시스템별 정보보안담당관(이하 "분임정보보안담당관"이라 한다)을 지정하여 운영할 수 있다.

② 위원회의 분임정보보안담당관은 다음 각 호와 같다.

1. 혁신행정담당관 : 공통행정(대표홈페이지, 인트라넷 등) 및 제도개선 시스템
2. 민원조사기획과장 : 고충e-시스템
3. 심사기획과장 : 청렴포털 시스템
4. 운영지원과장 : 인사관리, 기관관리 시스템
5. 홍보담당관 : 정책홍보관리 시스템
6. 국민신문고과장 : 온라인 국민참여포털 시스템
7. 민원정보분석과장 : 민원정보분석 시스템
8. 행정심판총괄과장 : 행정심판허브 시스템(온라인행정심판)
9. 정부합동민원센터 고충상담기획과장 : 정부합동민원센터 대표홈페이지, 정부민원안내콜센터
10. 청렴연수원 교육지원과장 : 청렴연수원 홈페이지
11. 그밖에 신규 구축되는 시스템 : 해당 정보시스템 관리·운영 부서장

③ 분임정보보안담당관은 다음 각 호의 업무를 수행하여야 한다.

1. 소관 정보시스템의 정보보호 업무
2. 소관 정보시스템에 대한 사이버공격 초동조치 및 침해사고 복구
3. 소관부서 정보시스템 및 휴대용 저장매체 보안관리
4. 정보보안담당관이 정보보안 업무를 위하여 취하는 조치 및 협조 요청 사항의 이행

④ 분임정보보안담당관은 소관 정보시스템의 정보보안담당자를 지정하고 그 사실을 정보보안담당관에게 통보하여야 한다.

제7조(정보보호실무협의회 운영) 정보보안책임관은 정보통신망의 안전성 확보를 위하여 정보보안담당관, 분임정보보안담당관, 정보시스템 관리자, 외부 정보보호 전문가 등으로 구성된 정보보호실무협의회를 구성·운영할 수 있다.

제8조(정보보호 규정 관리) ① 정보보안담당관은 연1회 이상 위원회 정보보호 규정의 적정성을 검토하여 필요시 제·개정하여야 한다. 이 경우 변경 내용을 국가정보원장과 사전에 협의하여야 한다.

② 정보보안담당관은 정보보호 관련 규정이 변경된 경우 그 내용을 전 직원에게 공지·배포하여야 한다.

제9조(세부추진계획 수립 및 심사분석) ① 정보보안담당관은 정보보안업무 세부추진계획(「국가사이버안전관리규정」 제9조에 따른 사이버안전대책을 포함한다)을 **수립·시행하여야 한다.**

제10조(정보보안 교육) ① 정보보안담당관은 정보보안 교육계획을 수립하고 연1회 이상 정보보안 교육을 실시하여야 한다.

② 정보보안담당관은 정보보안 관련 전문기관 교육 및 기술 세미나 참석을 장려하는 등 위원회 정보보안담당자의 업무 전문성을 제고하기 위하여 노력하여야 한다.

③ 정보보안담당관은 정보보안 교육을 실시하기 위하여 다음 각 호의 사항을 교육계획에 반영하여야 한다.

1. 교육 대상 및 목적
2. 교육 내용(프로그램 등 포함)
3. 교육 일정 및 시간
4. 교육 방법

④ 정보보안담당관은 다음 각 호의 대상자를 우선적으로 교육대상에 포함하여야 한다.

1. 부서 보안담당자(보안 업무 수행자)
2. 정보시스템(정보통신망 포함) 관리자 및 운영자
3. 응용시스템 개발자 및 유지 보수자
4. 개인정보보호담당자(개인정보 취급자)
5. 기타 정보보안 교육이 필요하다고 판단되는 대상자

⑤ 정보보안 교육 내용은 각 업무 담당자별로 "[별표 1] 교육대상자 별 교육내용

"을 참조하여 선정한다.

제11조(감사 계획수립) ① 정보보안담당관은 연1회 이상 정보보안 감사계획을 다음 각 호를 고려하여 수립한다.

1. 정보시스템 서비스의 중요도
2. 처리되는 정보의 중요도
3. 이전에 수행한 정보보안감사 결과

② 계획수립 시 다음 각 호에 대한 구체적인 범위 및 내용을 정의한다.

1. 정보보안 감사대상(대상 업무영역, 응용시스템, 서버팜, 네트워크구간 등을 명시적으로 정의)
2. 기간, 절차, 방법 등(정보보안감사 수행에 사용되는 구체적인 방법, 감사도구에 대한 요건 정의)

제12조(감사 전담반 구성) 정보보안담당관은 다음 각 호에 해당하는 인원을 포함하여 정보보안감사를 수행할 전담반을 구성할 수 있다.

1. 정보보안담당자(필수)
2. 서버관리자(필수)
3. 네트워크관리자(필수)
4. 응용시스템관리자(필요시 포함)

제13조(정보보안 감사) ① 정보보안담당관은 본부 및 소속기관의 정보통신에 대한 보안감사와 불시점검을 병행하거나 별도로 실시할 수 있다.

② 정보보안 감사를 수행할 전담반은 다음 각 호를 준수하여 정보보안 업무가 수행되고 있는지 평가하고, 필요시 정보시스템에 대한 정보보호 취약점은 취약점 진단 도구를 활용하여 점검한다.

1. 위원회 정보보호 규정
2. 국가 정보보안 기본지침
3. 국가사이버안전매뉴얼의 보안통제 항목
4. 기타 보안관련 통제 항목

③ 감사전담반은 정보보안감사 시 발견된 부적합 항목 및 주요 보안 취약점을 평가한 후 감사결과 부적합 항목과 관련된 각 관리부서에 전달한다. 각 관리부서에 전달되는 정보보안감사 결과에는 다음 각 호의 내용이 포함되어야 한다.

1. 정보보안감사 수행 일시
2. 정보보안감사 대상 (서버, 응용시스템, PC, 네트워크 장비 등)
3. 부적합 사항 (즉시 시정조치 되어야 하는 사항)
4. 권고 사항 (대책 수립 후 일정기간을 거쳐 시정조치 되어야 하는 사항)

④ 정보보안담당관은 다음 각 호를 포함하는 정보보안감사 결과 보고서를 위원장에게 보고한다.

1. 정보보안 감사 수행 일시, 대상 및 범위
2. 발견된 주요 정보보안 취약점 사항
3. 발견된 주요 정보보안 취약점 사항에 대한 시정조치 계획

⑤ 정보보안담당관은 정보보안감사의 효율적 수행을 위하여 국가정보원장에게 감사방향, 감사중점사항, 감사관 지원 등 업무협조를 요청할 수 있다.

제14조(지도방문) ① 정보보안담당관은 정보통신망 운영 관리에 따른 보안취약점 개선을 위하여 정보보안 지도방문(이하 "지도방문"이라 한다)을 실시하고, 그 결과를 제9조의 정보보안업무 심사분석에 포함시켜야 한다.

② 정보보안담당관은 본부 및 소속기관 등에 지도방문을 실시할 경우에는 " [별표 2] 정보보안 점검표"를 적극 활용하여야 한다.

③ 정보보안담당관은 정보통신망의 보안취약점 진단과 보안관리 개선을 위하여 국가정보원장에게 지도방문에 필요한 인력을 요청할 수 있다.

제15조 (보안관리 실태평가) 정보보안담당관은 「전자정부법」 제56조 및 같은법 시행령 제69조·제70조, 「공공기록물 관리에 관한 법률 시행령」 제5조의 규정에 따라 위원회 국가정보보안 정책 이행여부와 이행정도 등을 국가정보원이 구축한 온라인 평가 시스템을 이용하여 자체 평가를 실시하고 증빙자료 등을 첨부할 수 있다.

제16조(무선도청 탐지) ① 정보보안담당관은 무선도청에 따른 정보유출을 방지하기 위하여 다음 각 호의 시설 및 장소에 대한 보안대책을 강구하여야 한다.

1. 청사 신설·이전 또는 증·개축 시설
 2. 기관장실·회의실 등 중요시설
 3. 중요 협상·회의와 회담장소 또는 도청 의심징후가 있는 장소
- ② 정보보안담당관은 제1항 각호의 시설 및 장소에 대하여 국가정보원장에게 무선도청 탐지활동을 요청할 수 있다.
- ③ 정보보안담당관은 제2항에 의한 결과나 자체 무선도청 탐지활동 결과를 외부에 공개하여서는 아니 되며, 탐지활동결과 도출된 도청 취약요소 등에 대해서는 개선 대책을 강구하여야 한다.

제17조(사이버보안진단의 날) ① 정보보안담당관은 매월 셋째주 수요일을 '**사이버보안 진단의 날**'로 지정하여 운영하여야 한다.

② 정보보안담당관은 '**사이버보안 진단의 날**'에 PC진단프로그램 등을 활용하여 정보통신망의 악성코드 감염여부, 정보시스템의 보안 취약여부 등 정보보안업무 전반에 대하여 체계적이고 종합적인 보안진단을 실시하여야 한다.

제18조(유관기관과의 협조) 정보보안담당관은 정보통신망의 보호를 위하여 국가정보원 또는 기타 정보통신망 관리 기관과 다음 각 호의 사항에 대하여 상호 협조할 수 있다.

1. 정보통신망 보호에 필요한 정보의 공유
2. 침해사고 예방·대응 및 복구를 위한 상호협력 및 지원
3. 그 밖에 정보통신망의 보호를 위하여 상호협력이 필요한 사항

제3장 요소별 보안관리

제1절 정보통신망 기반관리 보안대책

제19조(정보통신망 보안관리) ① 위원장은 정보통신망과 관련한 다음 각 호에 해당하는 자료를 「보안업무규정 시행규칙」 제17조에 의거 국가정보원장이 배포한 「비밀세부분류지침」에 따라 보안 비밀로 분류·관리하여야 한다.

1. 국방 연구개발 및 정보통신 관련 자료
 2. 암호자재 운용현황
 3. 국가보안시설(보호장비 포함)의 운영·관리에 필요한 정보통신망 구성현황 (IP주소 할당현황 포함) 및 그에 대한 취약점 분석·평가 결과물(「정보통신기반 보호법」 제9조에 따른 취약점·분석 결과 포함)
 4. 그 밖에 제2항 각호에 해당하는 자료 중에서 국가정보원장이 비밀로 분류할 것을 요청한 자료
- ② 위원장은 제1항 각호에 해당하는 자료를 제외한 다음 각 호에 해당하는 자료를 「공공기관의 정보공개에 관한 법률」 제9조 제1항에 따른 비공개 대상 정보로 지정·관리하여야 한다.
1. 정보통신망 세부 구성현황(IP 세부 할당현황 포함)
 2. 보안시스템 운용현황
 3. 보안취약점 분석·평가 결과물
 4. 주요 정보화사업 추진현황
- ③ 정보보안담당관은 다른 기관 등과 정보통신망을 연결하여 사용하고자 할 경우에는 보안관리 책임한계 설정과 전산자료 제공범위 및 이용자 접근제한 등 정보통신망에 대한 보안대책을 수립·시행하여야 한다.
- ④ 정보보안담당관은 외부망과 연결에 따른 보안취약점 해소를 위하여 접속자료를 주기적으로 분석하고 보안도구를 이용한 정보통신망 안전측정을 통해 취약점을 수시 점검하여야 한다.
- ⑤ 정보보안담당관은 정보통신망을 상용망(인터넷 포함)이나 다른 기관과 정보통신망을 연계하기 위한 보안관리 연결지점을 운용할 경우에는 비인가자의 무단침입(불법접속)이나 악성코드 및 사이버공격을 방지하기 위하여 국가정보원장이 검증한 보안시스템의 설치·운용 등 보안대책을 강구하여야 한다.
- ⑥ 개인용 장비를 이용하여 상용망(인터넷 포함)을 통해 자료 또는 정보의 교환을 위하여 송수신할 경우에는 사전에 정보보안담당관의 승인을 받아 중요 정보자료의 무단유출을 방지하여야 한다.
- ⑦ 정보보안담당관은 인터넷을 통한 불법 사이트 접속이나 프로그램 다운로드를 금지하여야 하며 개인용 장비에서 불건전 정보·도박·증권 등 업무와 무관한

인터넷 사이트 접근에 대한 통제대책을 강구하여야 한다.

제20조(우회 정보통신망 보안관리) 각 부서는 모뎀, 인터넷 제공 업체 및 외부 정보통신망 등 우회 정보통신망을 사용할 수 없으며, 필요시 정보보안담당관의 사전 승인을 얻어야 하며 다음 각 호에 따라 사용현황을 관리하여야 한다.

1. 업무현황(업무명)
2. 제공업체
3. 우회 정보통신망 세부 구성현황(IP 세부 할당 현황 등)
4. 담당자 및 사용 시간

제21조(정보시스템 보안관리) ① 정보보안담당관은 정보시스템의 효율적인 보안관리를 위하여 정보시스템별로 관리책임자(이하 ‘시스템관리자’라 한다)를 지정 운영하여야 한다.

② 시스템관리자는 각종 서버·PC·정보통신장비·보안장비 등 정보시스템이 비인가자에게 불필요한 서비스를 허용하지 않도록 보안기능을 설정하여야 한다.

③ 시스템관리자는 보안도구를 이용하여 정보시스템의 보안취약점을 진단하여야 하며 이 경우 해당 정보시스템에 대한 접속·접근기록(일시, 사용자, 대상, 제목, 방법 등)을 관리하여야 한다.

④ 시스템관리자는 다음 각 호와 같이 자동 수록된 접근자료(Log Data)를 관리하여야 한다.

1. 접근자료는 접속의 성공여부와 무관하게 6개월 이상 기록 유지
2. 정보시스템 접근기록을 점검하고, 분석내용을 분기별로 부서장에게 보고
3. 자동 수록된 자료는 보안사고 발생 시 확인 등을 위하여 6개월 이상 보관
4. 접근자료의 외부유출 방지를 위한 보안대책 강구

⑤ 시스템관리자는 서버·네트워크장비 등 부서가 공동으로 사용하는 정보시스템의 운용·관리에 대한 보안책임을 진다.

⑥ 정보시스템 관리자는 소관 정보시스템에 대하여 중요도·가용성 등에 따라 등급을 분류하고 해당 등급에 맞게 정보 보존 및 관리, 장애관리, 보안관리 등을 수행하여야 한다.

- ⑦ 시스템관리자는 비인가자가 정보시스템에 침입한 사실을 인지한 경우에는 정보시스템의 보호를 위한 접속차단 등 초동 조치를 취하고 지체 없이 정보보안담당관에게 보고하여야 한다. 또한, 제86조(침해사고 초동조치) 및 제87조(사고통보 및 복구)에 따라 관련 내용을 정보보안담당관에게 통보·지원을 받아야 한다.
- ⑧ 사용자별 자료 접근범위는 서버에 등록하여 인가여부를 식별토록 하고 인가된 범위 이외의 자료접근을 통제하여야 한다.
- ⑨ 시스템관리자는 제3항 부터 제8항의 사항을 정보시스템 보안취약점 점검표(별지 제 12호 서식)를 이용하여 월1회 이상 점검·유지하고 정보보안담당관의 요구시 제출하여야 한다.
- ⑩ 정보보안담당관은 정보시스템에 대하여 외부업체의 원격 유지보수 작업을 허용하여서는 아니 된다. 다만, 부득이한 경우에는 접근 가능한 IP를 지정하고 한시적으로 허용하는 등 보안대책을 강구한 후 허용할 수 있으며, 이때에도 원격 유지보수 내용을 확인 감독하여 반드시 기록으로 유지하여야 한다.
- ⑪ 시스템관리자는 업무용 시스템 및 홈페이지 등 정보시스템의 서비스에 필요한 포트만 정보시스템 서비스 포트 관리대장(별지 제20호 서식)을 작성하여 문서로 유지하고 주기적 점검으로 불필요한 포트 확인 즉시 제거 또는 정보보호시스템으로 차단·요청하여야 한다.
- ⑫ 사용자는 개인 PC 등 소관 정보시스템을 사용하거나 본인 계정으로 정보통신망에 접속하는 것과 관련한 보안책임을 가진다.
- ⑬ 시스템관리자는 서버·네트워크장비 등 부서공통으로 사용하는 정보시스템의 운용과 관련한 보안책임을 가진다.
- ⑭ 정보시스템을 실제 운용하는 부서의 장이 정보시스템 '관리책임자'가 되며, 관리책임자는 정보시스템 관리대장(별지 제2호 서식)을 수기 또는 전자적으로 운용 관리하여야 한다.
- ⑮ 관리책임자는 해당 부서의 정보시스템 관리대장에 정보시스템의 변경 최종 현황을 유지하여야 한다.
- ⑯ 정보보안담당관은 정보시스템 운용과 관련한 보안취약점을 발견하거나 보안대책 강구가 필요하다고 판단할 경우, 사용자·시스템 관리자 및 관리책임자에게 시

정을 요구할 수 있다.

- 제22조(비밀의 전자적 처리)** ① 정보보안담당관은 비밀 등 중요 전자정보를 정보통신망을 이용하여 생산·보관·분류·열람·출력·송수신·이관하는 등 전자적으로 처리하기 위해서는 국가용 보안시스템을 사용하여 암호화하는 등 국가정보원장이 안전성을 확인한 보안조치를 수행하여야 한다.
- ② 제1항의 경우, 사용자는 업무망 전용 PC에서 비밀 등 중요 전자정보를 처리하여야 한다.
- ③ 사용자는 비밀을 전자적으로 생산하고자 할 때에는 해당 비밀등급과 예고문을 입력하여 열람 또는 출력시 비밀등급이 자동으로 표시되도록 하여야 한다.
- ④ 사용자는 비밀을 전자적으로 생산·보관·분류·열람·출력·송수신·이관시 관련 규격에 따른 제반사항을 전자적으로 기록 유지하여야 하며 송수신시에는 정당성 확인 및 부인을 방지하기 위하여 전자적으로 생성된 영수증을 사용하여야 한다.
- ⑤ 사용자는 비밀 생산을 완료한 경우에는 PC에 입력된 비밀내용을 삭제하여야 한다. 다만, 업무상 필요한 경우에는 비밀 저장용 휴대용 저장매체를 별도로 지정 사용하거나 PC내에 독립된 폴더를 지정, 국가용 보안시스템으로 암호화하여 보관하여야 한다.
- ⑥ 전자적으로 처리된 비밀을 종이문서로 출력한 이후의 취급 관리는 위원회 보안업무세칙에 따른다.

- 제23조(웹서버 등 공개서버 보안관리)** ① 본부 및 소속기관의 홈페이지 등 공개서버 시스템관리자는 외부인에게 공개할 목적으로 설치되는 웹서버 등 각종 공개서버를 내부망과 분리된 영역(DMZ)으로 분리하여 설치·운영하고 보안적합성이 검증된 보안시스템을 설치하는 등 보안대책을 강구하여야 한다.
- ② 서버관리자는 비인가자의 공개서버 중 비공개 정보에 대한 무단 접근을 방지하기 위하여 서버 접근 사용자를 제한하고 불필요한 계정을 삭제하여야 한다.
- ③ 공개서버 운영자는 서비스 개시 전 운영목표, 운영방침을 정하고 게시물 공개범위, 자료 게시 담당자 등 공개 기준을 설정해야 한다.
- ④ 공개서버 운영자는 홈페이지에 개인정보가 노출되지 않도록 개인정보 유출 차

단 필터링 시스템 도입 및 담당자 지정 모니터링 등을 실시하여야 한다.

⑤ 공개서버 운영자는 행사용·개발용 등 한시적 홈페이지를 주기적으로 확인하고 삭제하여야 한다.

⑥ 공개서버 운영자는 공개서버는 필요서비스를 제외한 모든 서비스 및 시험·개발도구(컴파일러 등)의 사용을 제한하도록 보안기능을 설정되어야 하며 안전측정을 통해 보안취약점을 수시로 점검하고 자료의 위·변조, 훼손 여부를 확인하여야 한다.

⑦ 공개서버 운영자는 보안 사고에 대비하여 서버에 저장된 자료의 철저한 백업체계를 구축하여야 하며 공개서버를 통해 개인정보가 유출, 위·변조되지 않도록 보안대책을 수립·시행하여야 한다.

⑧ 공개서버관리자는 비인가자의 분부·소속기관의 홈페이지 등 공개서버의 저장자료 절취, 위·변조 및 분산서비스거부(DDoS) 공격 등에 대비하기 위하여 국가정보원장이 안전성을 검증한 침입차단·탐지시스템 및 DDoS 공격대응시스템을 설치하는 등 보안대책을 강구하여야 한다.

제24조(영상회의시스템 보안관리) ① 각 부서에서 영상회의시스템을 구축할 경우 통신망(국가정보통신망, 전용선, 인터넷 등)에 따른 암호화 등 보안대책을 수립하고, 정보보안담당관의 사전 승인을 얻어야 한다.

② 기타 세부적인 사항은 「부처 영상회의시스템 보안가이드라인」(2013.4 국가정보원)을 준수하여야 한다.

제25조(모바일 및 사물인터넷 장비 보안관리) ① 각 부서에서 스마트폰 등을 활용하여 내부행정업무와 현장행정업무 및 대민서비스 업무 등 모바일 업무환경을 구축할 경우 보안대책 수립하고, 정보보안담당관의 사전 승인을 얻어야 한다.

② 기타 세부적인 사항은 「국가·공공기관 모바일 활용업무에 대한 보안가이드라인」(2014. 국가정보원)을 준수하여야 한다.

③ 사물인터넷을 이용한 시스템을 구축·운영하고자 할 경우 사물인터넷 기기 및 중요 데이터 등을 보호하기 위하여 보안대책을 수립·시행하여야 한다.

④ 사물인터넷을 이용한 시스템을 구축·운영하고자 할 경우 내부망과 분리하여

야 한다. 다만, 내부망과 연동이 필요한 경우에는 망간 자료전송제품 설치 등 보안대책을 수립하여야 한다.

⑤ 기타 사물인터넷 보안과 관련한 사항은 국가정보원장이 배포한 「국가·공공기관 사물인터넷(IoT) 보안가이드라인」을 준수하여야 한다.

제26조(클라우드 시스템 보안관리) ① 정보보안담당관 및 분임정보보안담당관(이하 '정보시스템부서장'이라 한다)은 「클라우드 컴퓨팅 발전 및 이용자 보호에 관한 법률」 제12조에 따라 클라우드컴퓨팅을 자체 구축·운영하고자 할 경우 국가정보원장이 배포한 「국가·공공기관 클라우드 컴퓨팅 보안 가이드라인」(2019. 국가정보원)에 명시된 기관 자체 클라우드컴퓨팅 구축 보안기준에 따라 대책을 수립·시행하여야 한다.

② 각 정보시스템부서장은 민간 클라우드컴퓨팅서비스를 이용하고자 할 경우 다음 각 호에 해당하는 사항을 준수하여야 한다.

1. 국내에 위치한 정보시스템에 데이터가 저장되는 서비스로서 일반 이용자용 서비스 영역과 물리적으로 분리되어 제공되는 서비스 영역(이하 "공공 전용(專用) 클라우드"라 한다)에 한하여 활용
2. 과학기술정보통신부장관이 고시한 「클라우드컴퓨팅서비스 정보보호에 관한 기준」에 부합하는 서비스 선정
3. 국가정보원장이 배포한 「국가·공공기관 클라우드 컴퓨팅 보안 가이드라인」에서 제시하는 민간 클라우드컴퓨팅서비스 이용 보안기준 및 행정안전부장관이 배포한 「행정·공공기관 민간 클라우드 이용 가이드라인」에 따른 절차 이행

③ 위원회의 내부망과 연동된 공공 전용(專用) 클라우드는 이 지침을 적용함에 있어 위원회의 내부망으로 본다.

④ 위원회의 인터넷망과 연동된 공공 전용(專用) 클라우드는 이 지침을 적용함에 있어 위원회의 인터넷망으로 본다.

제27조(사용자계정 관리) ① 시스템관리자는 사용자에게 정보시스템 접속에 필요한 사용자계정(ID) 부여 시 비인가자 도용 및 정보통신시스템 불법 접속에 대비하여 다음 각 호의 사항을 반영하여야 한다.

1. 사용자별 또는 그룹별로 접근권한 부여
2. 외부인에게 계정 부여는 불허하되 업무상 불가피한 경우 시스템관리부서의 장 책임하에 필요 업무에 한해 특정기간 동안 접속토록 하는 등 보안조치 강구 후 허용
3. 비밀번호 등 사용자 식별 및 인증 수단이 없는 사용자계정 사용 금지
- ② 시스템관리자는 사용자가 5회 이상에 걸쳐 로그인 실패시 정보시스템 접속을 중단시키도록 시스템을 설정하고 비인가자의 침입 여부를 확인 점검하여야 한다.
- ③ 시스템관리자는 직원의 퇴직 또는 보직변경 발생시 사용하지 않는 사용자 계정을 신속히 삭제하여야 한다.
- ④ 시스템관리자는 업무상 불가피한 경우를 제외하고는 유지보수 등을 위한 외부업체 직원에게 관리자 계정 제공을 금지하여야 한다.
- ⑤ 정보보안담당관은 사용자계정의 부여·관리 현황을 연 2회 이상 실태점검하고, 취약요소가 있을 경우 시스템관리자에게 개선을 요청할 수 있다.

제28조(비밀번호 관리) ① 사용자는 비밀번호 설정시 정보시스템의 무단사용 방지를 위하여 다음 각 호와 같이 구분하여야 한다.

1. 비인가자의 정보시스템 접근방지를 위한 장비 접근용 비밀번호(1차)
2. 정보시스템 사용자가 서버 등 정보통신망에 접속 인가된 인원인지 여부를 확인하는 사용자인증 비밀번호(2차)
3. 문서 열람·수정 및 출력 등 사용권한을 제한할 수 있는 자료별 비밀번호(3차)
- ② 사용자는 비밀이나 중요자료에는 비밀번호를 반드시 부여하되, 공개 또는 열람 자료에 대해서는 부여하지 않을 수 있다.
- ③ 비밀번호는 다음 각 호의 사항을 반영하여 숫자와 문자, 특수문자 등을 혼합하여 9자리 이상으로 정하고, 분기별로 1회 이상 주기적으로 변경 사용하여야 한다.
1. 사용자계정(ID)과 동일한 비밀번호 사용 금지
2. 개인 신상 및 부서명칭 등과 관계된 비밀번호 사용 금지

3. 동일단어 또는 반복 숫자 사용 금지
4. 사용한 비밀번호 재사용 금지
5. 동일 비밀번호 여러 사람 공유 사용 금지
6. 응용프로그램 등을 이용한 자동 비밀번호 입력기능 사용 금지
- ④ 정보시스템 관리자는 서버에 저장된 비밀번호는 암호화하여 저장하여야 한다.

제29조(업무망 보안관리) ① 정보보안담당관은 업무자료를 소통하기 위한 전산망 구축시 인터넷과 분리하도록 망을 설계하여야 한다. 이 경우 다음 각 호의 보안대책을 강구하여 사업 계획단계(사업 공고 전)에서 국가정보원장에게 보안성 검토를 의뢰하여야 한다.

1. 비인가자의 업무망·인터넷 침입 차단대책(침입차단·탐지시스템 등)
2. 비인가 장비의 업무망 접속 차단대책(네트워크 관리시스템 등)
3. 업무PC의 인터넷 접속 차단대책
4. 업무망과 인터넷망간 안전한 자료전송 대책(「국가·공공기관 업무망과 인터넷간 안전한 자료전송 보안가이드라인」(2010.8, 국가정보원) 참조)
- ② 업무망 관리자는 정보시스템에 부여되는 'IP주소'를 체계적으로 관리하여야 하고, 비인가자로부터 업무망을 보호하기 위하여 사설주소체계(NAT)를 적용하여야 한다. 또한, IP주소별로 정보시스템 접속을 통제하여 비인가 정보통신기구나 PC 등을 이용한 업무망 내 정보시스템 접속을 차단하여야 한다.
- ③ 업무망을 여타 기관의 망 및 인터넷과 연동하고자 할 경우에는 보안관리 책임 한계를 마련하여 국가정보원장에게 보안성 검토를 의뢰하여야 한다.
- ④ 업무망 관리자는 비인가자의 망 침입을 방지하기 위하여 안전성이 검증된 침입차단·탐지시스템을 운영하는 등 보안대책을 강구하여야 한다.
- ⑤ 업무망 관리자는 업무망을 인터넷과 연동시 효율적인 보안관리를 위하여 연결지점을 최소화하여 운용하여야 한다.
- ⑥ 정보보안담당관은 업무망의 외부망 연결에 따른 보안취약점 해소를 위하여 보안진단 도구를 이용하여 수시 점검하여야 한다.
- ⑦ 정보보안담당관은 업무망과 인터넷망 간의 자료 교환은 망간자료전송시스템을 사용하도록 시스템을 구축하여야 하며, 전송로그는 6개월 이상, 원본파일은 3

개월 이상 유지하여야 한다.

제30조(네트워크장비 보안관리) ① 시스템관리자는 라우터, 스위치 등 네트워크 장비 운용과 관련하여 다음 각 호의 보안조치를 강구해야 한다.

1. 네트워크 장비에 대한 원격접속은 원칙적으로 금지하되, 불가피할 경우 장비관리용 목적으로 내부 특정 IP·MAC주소에서의 접속은 허용
2. 물리적으로 안전한 장소에 설치하여 비인가자의 무단접근 통제
3. 최초 설치 시 보안취약점을 점검하여 제거하고 주기적으로 보안패치 실시
4. 불필요한 서비스 포트 제거

② 시스템관리자는 네트워크장비의 접속기록을 1년 이상 유지하여야 하고 비인가자의 침투 여부를 주기적으로 점검하여 정보보안담당관은 관련결과를 확인할 수 있다.

제31조(이동통신망 보안관리) ① 정보시스템부서장은 이동통신망(HSDPA, WCDMA, LTE, 5G 등) 시스템을 구축하여 업무자료를 소통하고자 할 경우 자체 보안대책을 수립하여 관련 사업 계획단계(사업 공고 전)에서 정보보안담당관을 경유하여 국가정보원장에게 보안성 검토를 의뢰하여야 한다.

② 정보시스템부서장은 이동통신망(HSDPA, WCDMA, LTE, 5G 등)을 이용하여 시스템을 구축하거나 중요자료를 소통하고자 할 경우 암호화 및 비인가 단말기의 이동통신망 접속 차단 등 기술적 보안 대책을 수립·시행하여야 한다.

③ 제2항에 따라 이동통신망을 이용한 시스템을 구축·운용할 경우 위원회의 정보통신망과 혼용되지 않도록 하여야 한다.

제32조(무선랜 보안관리) ① 정보시스템부서장은 무선랜(와이파이 등)을 사용하여 업무 자료를 소통하고자 할 경우 자체 보안대책을 수립하여 관련 사업 계획단계(사업 공고 전)에서 정보보안담당관을 경유하여 국가정보원장에게 보안성 검토를 의뢰하여야 한다.

② 정보시스템부서장은 제1항의 보안대책 수립 시, 다음 각 호의 사항을 포함하여야 한다.

1. 네트워크 이름(SSID, Service Set Identifier) 브로드캐스팅 중지
 2. 추측이 어려운 복잡한 SSID 사용
 3. WPA2 이상(256비트 이상)의 암호체계를 사용하여 소통자료 암호화
 4. 비인가 단말기의 무선랜 접속차단 및 무선랜 이용 단말기를 식별하기 위한 IP주소 할당기록 등 유지
 5. IEEE 802.1X, AAA(Authentication Authorization Accounting) 등의 기술에 따라 상호 인증을 수행하는 무선랜 인증제품 사용
 6. 무선침입방지시스템 설치 등 침입 차단대책
 7. 기관의 내부망 정보시스템 또는 인접해 있는 다른 기관의 정보시스템이 해당 무선랜에 접속되지 아니하도록 하는 기술적 보안대책
 8. 그 밖에 무선랜 단말기·중계기(AP) 등 구성요소별 분실·탈취·훼손·오용 등에 대비한 관리적·물리적 보안대책
- ③ 정보보안담당관은 제2항 및 제3항과 관련한 보안대책의 적절성을 수시로 점검하고 취약점을 보완하여야 한다.
- ④ 정보시스템부서장은 내부망을 제외한 정보통신망에서 다음 각 호의 경우와 같이 청사 내에 무선랜(Wifi)을 구축·운용할 수 있다.
1. 기관 인터넷망에 중계기(AP)를 설치하여 제37조제1항에 따라 위원장이 지급한 단말기의 접속만을 허용하는 업무용 무선랜
 2. 상용 인터넷망에 중계기(AP)를 설치하여 제38조(PC보안설정)에 따라 반입한 공무원등의 개인 소유 이동통신단말기의 접속만을 허용하는 무선랜
 3. 상용 인터넷망에 중계기(AP)를 설치한 외부인 전용 무선랜

제33조(인터넷전화 보안관리) ① 정보보안담당관은 인터넷전화 시스템을 구축하거나 민간 인터넷전화 사업자망(070)을 사용하고자 할 경우에는 사업 계획단계에서 자체 보안대책을 수립 시행하여야 한다.

② 시스템관리자는 제1항의 보안대책 수립시, 다음 각 호의 사항을 포함하여야 한다.

1. 인터넷전화기에 대한 장치 인증 및 사용자 인증
2. 제어신호 및 통화내용의 암호화
3. 인터넷전화망(음성 네트워크)과 일반 전산망(데이터 네트워크)의 분리

4. 인터넷전화 전용 방화벽 등 정보보호시스템

5. 백업체계 구축

③ 시스템 관리자는 인터넷전화 시스템 구축을 위하여 민간 사업자망을 이용할 경우, 해당 사업자로 하여금 서비스 제공 구간에 대한 보안대책을 강구하도록 하여야 한다.

④ 인터넷전화 구축시 보안관리에 관련된 구체적인 사항은 국가정보원 인터넷전화 구축시 보안준수사항에 따른다.

제34조(원격접속 보안) ① 정보보호시스템 관리자는 정보보호시스템을 원격으로 관리할 수 없다. 다만, 부득이한 경우는 정보보안담당관의 승인 하에 원격으로 관리하되 다음 각 호의 사항을 준수하여야 한다.

1. 원격관리 시간을 최소화

2. 원격관리자의 접속 비밀번호 임시 부여 및 소통내용 암호화 등 보안대책 적용

3. 인가되지 않은 원격관리가 수행되는지 주기적 확인 점검

② 정보보안담당관은 제1항에 의한 승인을 위하여 다음 각 호의 사항을 확인하는 등 보안조치를 수행하여야 한다.

1. 원격 접속할 사용자의 계정 및 비밀번호

2. 접속주소, 접속시간

3. 원격접속 사유(출장, 전산망 유지보수 등)

4. 원격접속 후 사용자계정 및 패스워드 회수 등 조치사항

5. 정보보호시스템 운용현황(별지 제6호 서식)

③ 재택근무, 출장지 현장 근무, 또는 파견 근무시 인터넷을 통해 본인 인증을 거쳐 기관 정보시스템에 접속하여 온라인상으로 수행하는 업무를 수행(이하 "원격근무"라 한다)하게 할 수 있다.

④ 제1항에 따른 원격근무를 위해 접속할 수 있는 기관 정보시스템은 다음 각 호와 같다.

1. 행정안전부 국가정보자원관리원 원격근무서비스 시스템

2. 제75조 제1항 제15호에 근거해 구축한 원격근무서비스 시스템

⑤ 제1항에 따른 원격근무로 취급할 수 있는 업무자료의 범위는 공개 및 비공개 업무자료로 한다.

⑥ 원격근무자는 원격근무용 단말기(개인 소유의 정보통신기기를 포함한다)의 보안을 위하여 취하는 다음 각 호의 조치에 적극 협조하여야 한다.

1. 제38조에 따른 단말기(PC) 보안대책 준수 및 위원회에서 제공하는 보안소프트웨어 설치·운영

2. 사이버공격 등으로 인한 자료유출 사고 발생시 제90조(정보보안사고조사)에 따라 정보보안담당관에게 즉각 사고 상황을 알리고 조사에 적극 협조

⑦ 원격업무 시스템 관리자는 원격근무자에게 보안서약서를 제출받은 후 직위·임무에 부합한 정보시스템 접근권한 부여 및 보직변경·퇴직 등 변동사항 발생 시 접근권한 조정 등의 절차를 마련·시행하여야 한다.

제2절 인적보안 관리

제35조(인적보안) ① 정보보안담당관은 소관 정보통신망(정보시스템 포함) 사용과 관련하여 사용자의 직위·임무별 정보통신망 접근 자격부여 심사 등 인적보안에 관련된 절차 및 방법을 마련하여야 한다.

② 보안담당관은 정보통신망을 통하여 비밀 등 중요정보를 취급하는 사용자에게 대해서는 비밀취급인가, 보안서약서 징구 등의 보안조치를 하여야 한다.

③ 분임정보보안담당관은 사용자가 보직변경, 퇴직 등 인사이동이 있을 경우 관련 정보 시스템 접근권한을 조정하여야 한다.

④ 분임정보보안담당관은 외부 인력을 활용하여 정보시스템의 개발, 운용, 정비 등을 수행할 경우에는 해당 인력의 고의 또는 실수로 인한 정보유출이나 파괴를 방지하기 위하여 보안조치를 수행하여야 한다.

제36조(업무대행자 보안관리) ① 정보보안담당관은 정보시스템을 관리하기 위하여 기간제 근로자, 청원경찰, 공익근무요원 등을 업무대행자로 지정하여서는 아니 된다. 다만, 부득이한 경우에는 정보보안담당관의 승인 하에 지정하되, 다음 각 호의 사항을 준수하여야 한다.

1. 정보시스템 접속시간 최소화
2. 정보시스템의 접속 비밀번호 임시 부여 및 소통내용 암호화 등 보안대책 적용
3. 인가되지 않은 정보시스템 접속 여부의 주기적 확인점검
- ② 정보보안담당관이 제1항에 의하여 특정 정보시스템에 대해 업무대행자를 지정한 경우에는 다음 각 호의 사항을 확인하는 등 보안조치를 수행하여야 하며, 그 사유가 소멸 시에는 즉시 해지하여야 한다.
 1. 접속할 사용자, 사용자계정, 비밀번호
 2. 접속주소, 접속시간, 접속사유(자료입력, 통계작성 등)
 3. 접속 종료 후 사용자계정 및 비밀번호 회수 등 조치사항
 4. 보안·비밀유지서약서(별지 제3호 서식) 징구 및 사용자 계정 관리대장(별지 제7호 서식) 작성 비치

제3절 PC 보안관리

제37조(PC 관리책임) ① 정보시스템부서장은 PC, 노트북, 휴대단말(PDA) 등 단말기를 사용하고자 할 경우에는 관리책임자를 지정하여 관리하여야 하며, PC·단말기(저장자료를 포함한다)의 정보보안 관리 책임은 사용자에게 있다.

② 관리책임자는 PC·노트북 관리대장(별지 제21호 서식)을 활용하여 분기별로 현황을 관리하여야 하며, 정보보안담당관의 요구 시 제출하여야 한다.

제38조(PC 보안설정) ① 사용자는 업무상 사용하는 PC에 대한 보안설정을 "[별표 3] PC 보안 설정"에 준하여 설정하여야 한다.

② 관리책임자는 비인가자가 PC를 무단으로 조작하여 전산자료를 유출, 위·변조 및 훼손시키지 못하도록 다음 각 호에 따라 관리하여야 한다.

1. 장비(CMOS비밀번호)·자료(문서자료 암호화 비밀번호)·사용자(로그온 비밀번호)별 비밀번호를 주기적으로 변경 사용
2. 10분 이상 PC 작업 중단 시 화면보호 조치
3. PC용 최신 백신 운용·점검 운용체제 및 응용프로그램(아래아한글, MS

- Office 등) 최신 보안 패치 유지
4. P2P, 웹하드 등 자료의 유출이 가능하고 업무와 무관하거나 보안에 취약한 프로그램의 사용 금지
 - ③ 사용자는 PC 등을 교체·반납·폐기하거나 고장으로 외부에 수리를 의뢰하고자 할 경우에는 정보보안담당관과 협의하여 하드디스크에 수록된 자료가 유출, 훼손되지 않도록 보안조치 하여야 한다.
 - ④ 관리책임자는 사용자가 PC 등을 기관 외부로 반출하거나 내부로 반입할 경우에 최신 백신 등을 활용하여 해킹프로그램 감염 여부를 점검하여야 한다.
 - ⑤ 누구든지 개인 소유의 PC 등을 무단 반입하여 사용하여서는 아니 된다. 다만, 부득이한 경우에는 정보보안담당관의 승인을 받아 사용할 수 있다.

제39조(인터넷PC 보안관리) ① 정보보안담당관은 비인가자가 인터넷과 연결된 PC(이하 "인터넷PC"라 한다)를 무단으로 조작하여 전산자료를 절취, 위·변조 및 훼손시키지 못하도록 다음 각 호의 보안대책을 사용자에게 지원하며, 사용자는 이를 준수하여야 한다.

1. 메신저·P2P·웹하드 등 업무에 무관하거나 Active-X 등 보안에 취약한 프로그램과 비인가 프로그램·장치의 설치 금지
2. 특별한 사유가 없는 한 문서프로그램은 읽기 전용으로 운용
3. 음란·도박·증권 등 업무와 무관한 사이트 접근차단 조치
4. 업무자료 저장을 금지하기 위한 기술적·관리적 조치
- ② 사용자는 인터넷PC에서 무단으로 업무자료의 작성·저장 및 소통을 금지하고 최신 백신을 활용하여 바이러스 감염 여부를 주기적으로 점검하여야 한다.
- ③ 그 밖에 인터넷 PC의 보안관리에 관련한 사항에 대해서는 제38조(PC 보안설정)를 따른다.

제40조(PC 하드웨어 관리) ① 사용자는 PC·단말기나 PC·단말기에 설치 또는 부착된 하드웨어를 임의로 부서 밖으로 반출하거나 반입해서는 안 된다.

② 관리책임자는 PC·단말기 내에 설치 또는 부착된 하드웨어를 임의로 변경·제거하지 못한다.

- ③ 사용자는 퇴근, 휴가 등 일정 기간 노트북을 사용하지 않을 경우 시건 장치가 있는 안전한 장소에 보관한다.
- ④ 사용자는 CD Writer, 모뎀, 착탈식 디스크 등의 주변장치를 임의적으로 설치해서는 안 된다.

제41조(소프트웨어 설치제한) ① 사용자는 위원회의 소프트웨어는 업무상의 인가된 목적으로만 사용되어야 하며, 불법 소프트웨어는 설치·사용할 수 없다.

② 사용자는 위원회의 정보시스템을 침해하거나 우회할 수 있는 소프트웨어를 임의로 설치해서는 안 된다.

③ 사용자는 원격지에서 목적 없이 개인의 PC·단말기를 관리할 수 있는 소프트웨어를 임의로 설치해서는 안 된다.

④ 사용자는 업무용 목적 이외의 프로그램(게임, 증권 등)을 PC에 설치해서는 안 된다.

제42조(공유폴더 관리) 사용자는 공유폴더는 사용하지 않는 것을 원칙으로 하며, 업무상 목적에 의해 폴더를 공유할 경우 다음 각 호의 조치를 취하여야 한다.

1. 필요에 의해 공유를 하여야 할 시에는 반드시 비밀번호를 설정하여 사용하여야 하고 사용이 완료된 후에는 공유를 제거토록 한다.
2. 파일의 전달 시에는 반드시 일기 권한만을 주어 비밀번호를 설정하고, 상대방이 쓰기를 하여야 하는 경우에 있어서만 쓰기 권한을 주고 패스워드를 설정하여야 한다.

제43조(PC 정보보안 사고 대응) ① 관리책임자는 PC·단말기 관련 정보보호 침해 사고 발생 시 정보보안담당관에게 보고하여야 하며, 관련 기록을 보존 한다.

② 사용자는 PC·단말기에 접근하기 위해 사용되는 비밀번호가 노출되었거나 노출이 의심되는 경우, 비밀번호를 변경하여야 한다.

③ 사용자는 정보보안 사고를 미연에 방지하기 위해 인터넷이 연결된 PC·단말기에는 행정전자서명 및 업무자료를 저장할 수 없다.

④ 정보보안담당관은 침해사고 발생 시 제86조(침해사고 초동조치) 및 제87조(사

고통보 및 복구)에 따라 관련 내용을 국가정보원장에게 통보·지원을 받아야 한다.

제44조(유지보수 보안) ① PC를 유지보수 할 경우에는 PC 사용자의 사무실 내에서 인가된 직원이 직접 방문하여 수리하는 것을 원칙으로 한다.

② 제1항에도 불구하고 PC 및 저장매체를 이동·반출할 경우 PC사용자는 제56조(저장매체 보안관리)에 따라 저장매체에 저장된 데이터가 복구되지 않도록 삭제한 후 반출하여야 한다.

제4절 전자우편 및 인터넷 사용보안

제45조(전자우편 보안) ① 전자우편 시스템관리자는 웜·바이러스 등 악성코드로부터 사용자 PC 등 전자우편 시스템 일체를 보호하기 위하여 정보보안담당관이 안전성을 확인한 백신, 바이러스 웜, 해킹메일 차단시스템을 구축하는 등 보안대책을 강구하여야 한다.

② 전자우편 사용자는 상용 전자우편을 이용한 업무자료 송·수신을 할 수 없으며, 공직자 통합메일로 송·수신한 업무자료는 열람 등 활용 후 메일함에서 즉시 삭제하여야 한다.

③ 사용자는 중요자료를 외부와 송·수신할 경우에는 반드시 소통 내용 및 첨부파일을 비밀번호를 걸어 사용하여야 한다.

④ 사용자는 메일에 포함된 첨부파일이 자동 실행되지 않도록 설정하고 첨부파일 다운로드시 반드시 최신 백신으로 악성코드 은닉여부를 검사하여야 한다.

⑤ 사용자는 출처가 불분명하거나 의심되는 제목의 전자우편은 열람을 금지하고 해킹메일로 의심되는 메일 수신시 즉시 정보보안담당관에게 신고하여야 한다.

⑥ 사용자는 해킹메일을 열람한 경우 원인 규명 등을 위하여 파일 임의삭제 등 감염 시스템 사용을 중지하고 전산망과의 접속을 신속히 분리한 후 정보보안담당관에게 관련 사실을 즉시 신고하여야 한다.

제46조(인터넷 사용 보안) ① 위원회 직원은 근무 시간 중 위원회 정보통신망에서 다음과 같은 목적으로는 인터넷을 사용할 수 없다.

1. 위원회에 심각한 영향을 줄 수 있는 중요 정보의 송수신 행위
 2. 사회적으로 물의와 문제를 야기 시킬 수 있는 정보(메일)의 교환
 3. 사회 미풍양속을 해칠 수 있는 불건전 사이트 열람이나 파일의 다운로드 및 배포
 4. 저작권을 침해할 수 있는 불법적인 자료의 취득, 배포
 5. 타 직원의 업무 수행을 방해할 수 있는 모든 행위
 6. 개인의 사업목적 용도의 행위
 7. 기타 보안 규정에 의한 금지 사항
- ② 정보보안담당관은 인터넷상의 특정 사이트에 대해서 정상적인 업무 활동을 위해 다음 각 호에 해당되는 사이트의 접속을 금지할 수 있다.
1. 사이버 주식, 게임, 도박, 불건전 정보를 포함하는 업무와 무관한 사이트
 2. 사용 시 위원회의 정보 유출이 우려되는 사이트(P2P, 메신저, 웹하드, 공개 메일 사이트 등)를 포함한 위원회의 정상적인 업무 활동을 위해 차단이 요구되는 사이트
 3. 기타 국가정보원 등 내·외부기관에서 차단을 요청한 사이트
- ③ 위원회 내부정보를 제공하는 비공식적인 인터넷 웹사이트 구축을 금한다.
- ④ 웹하드 및 인터넷 디스크 등 인터넷 상에 제공되는 외부의 저장공간에 업무적으로 취득한 자료를 저장할 수 없다.

제47조(악성코드 감염 방지대책) ① 정보보안담당관은 웜·바이러스, 해킹프로그램, 스파이웨어 등 악성코드 감염을 방지하기 위하여 다음 각 호와 같은 대책을 수립·시행하여야 한다.

1. 사용자는 개인 PC에서 작성하는 문서·데이터베이스 작성기 등 응용프로그램을 보안패치하고 백신은 최신상태로 업데이트·상시 감시상태로 설정 및 주기적인 점검을 실시하여야 한다.
2. 사용자는 출처, 유통경로 및 제작자가 명확하지 않은 응용프로그램 사용을 금지하고 인터넷 등 상용망으로 자료 입수 시 신뢰할 수 있는 인터넷사이트를 활용하되 최신 백신으로 진단 후 사용하여야 한다.
3. 사용자는 인터넷 파일공유 프로그램과 메신저·대화방 프로그램 등 업무상 불필요한 프로그램을 사용 금지하고 시스템관리자는 인터넷 연동구간의

침입차단시스템 등에서 관련 사이트 접속을 차단하도록 보안설정 하여야 한다.

4. 사용자는 웹 브라우저를 통해 서명되지 않은 (Unsigned) Active-X 등이 PC 내에 불법 다운로드 되고 실행되지 않도록 보안 설정하여야 한다.
 5. 제1호부터 제4호까지의 보안대책과 관련하여 시스템관리자는 정보보안담당관과 협조하여 사용자가 적용할 수 있는 보안기술을 지원하여야 한다.
- ② 시스템관리자 또는 PC 등의 사용자는 시스템 및 PC등에 악성코드가 설치되거나 감염된 사실을 발견하였을 경우에 다음 각 호의 조치를 하여야 한다.
1. 악성코드 감염원인 규명 등을 위하여 파일 임의삭제 등 감염 시스템 사용을 중지하고 전산망과의 접속을 신속히 분리한다.
 2. 악성코드의 감염확산 방지를 위하여 정보보안담당관에게 관련 사실을 즉시 통보한다.
- ③ 제2항의 조치가 완료된 후 제87조(사고통보 및 복구)에 따라 정보보안 사고 조사권한이 정보보안담당관에게 위임되었을 경우, 정보보안담당관은 감염PC 등에 대하여 다음 각 호의 조치를 하여야 한다.
1. 최신 백신 등 악성코드 제거 프로그램을 이용하여 악성코드를 삭제한다.
 2. 감염이 심각할 경우 포맷 프로그램을 사용하여 하드디스크를 포맷한다.
 3. 악성코드 감염의 확산 및 재발을 방지하기 위하여 원인을 분석하고 예방조치를 수행한다.
- ④ 정보보안담당관은 악성코드가 신종이거나 감염피해가 심각하다고 판단할 경우에는 관련사항을 국가정보원장에게 신속히 통보하여야 한다.
- ⑤ 정보보안담당관은 국가정보원장이 악성코드 감염사실을 확인하여 조치를 권고할 경우, 즉시 이행하여야 한다.
- ⑥ 그 밖에 정보보안 사고 조사와 관련한 사항에 대해서는 제90조(정보보안 사고 조사)를 따른다.

제5절 전자정보 보안관리

제48조(전자정보 보안조치) 정보보안담당관은 정보통신망을 통하여 보관·유통되는

전자정보의 보안을 위하여 다음 각 호의 조치를 이행하여야 한다.

1. 정보보안 책임 및 기본활동 수행
2. 전자정보 보안대책 이행
3. 국가용 보안시스템의 사용
4. 정보보호시스템의 도입 운용
5. 정보통신망 보안대책의 수립·시행
6. 국가정보원장이 발행한 지침·매뉴얼 및 각종 권고사항의 이행
7. 기타 전자정보 보안을 위하여 필요하다고 인정되는 보안대책의 이행

제49조(일반 전자정보 보호등급 분류) ① 정보보안담당관은 비밀이 아닌 중요 전자정보의 효율적 보호를 위하여 다음 각 호에 해당하는 경우에는 자체 실정에 맞는 보호등급으로 분류하여야 한다.

1. 최초로 정보통신망을 신설하여 전자정보의 보호등급 구분이 필요한 경우
 2. 현재 운용중인 정보통신망을 재구성할 경우
 3. 정보보안담당관이 필요하다고 인정하는 경우
- ② 제1항의 규정에 의한 전자정보의 보호등급 분류는 다음 각 호와 같이 구분한다.
1. ‘가’급
유출 또는 손상되는 경우 위원회의 업무수행에 중대한 장애를 초래 하거나 개인 신상에 심각한 영향을 줄 수 있는 전자정보
 2. ‘나’급
유출 또는 손상되는 경우 위원회의 업무수행에 장애를 초래 하거나 개인 신상에 영향을 줄 수 있는 전자정보
 3. ‘다’급
유출 또는 손상되는 경우 위원회의 업무수행 및 기관의 이미지에 경미한 영향을 줄 수 있는 전자정보
- ③ 정보보안담당관은 제2항의 규정에 따라 전자정보 보호등급을 분류하기 위한 자체 기준을 수립하여야 한다. 다만, 소속기관에 대한 기준 수립은 감독기관의 장이 행한다.

제50조(정보자산의 분류 주기) ① 전산자료 및 정보자산 보호등급 분류는 연 1회 수행하는 것을 원칙으로 한다.

② 정보자산을 신규 도입하거나 변경이 발생한 경우 정보자산의 검수가 완료된 시점 및 변경이 완료된 시점에 보호등급 분류를 수행한다.

③ 정보보안담당관은 각 정보자산 관리자로 하여금 해당 자산의 분류 및 중요도 평가 또는 검토를 요구할 수 있다.

제51조(전산자료 보안관리) ① 정보보안담당관은 전산자료에 대한 유출이나 파괴 또는 위·변조 등에 대비하여 다음 각 호에 정하는 보안대책을 강구하여야 한다.

1. 자료 복사본(예비) 확보하여 안전한 장소에 별도 보관
 2. 전산자료(보조기억매체 포함) 보유현황 관리
 3. 전산자료 및 장비의 반출 또는 반입 통제
 4. 불법접근 및 해킹프로그램·웜·바이러스 감염 피해 예방
 5. 전산자료 접근권한 구분·통제
- ② 전산자료를 입력 저장하기 위한 보조기억매체는 각 매체별로 별개의 관리 번호를 부여 관리하여야 하며, 비밀 등 중요자료가 입력된 보조기억매체는 위원회 **부록 1**의 "USB메모리 등 휴대용저장매체 보안관리지침"에 따른다.
- ③ 보조기억매체를 활용하는 부서의 보안담당자는 연 2회 이상 보유현황 및 관리실태를 점검하고 부서장의 확인을 받아야 한다.
- ④ 비밀로 분류하지 않더라도 민감한 보고서나 자료에 대해서는 자료별 접근 패스워드를 사용하고 보조기억매체를 적극 활용하여야 한다.
- ⑤ 직원의 퇴직 시 정보자산과 업무자료의 불법 반출·이동을 통제하기 위해 부서 보안담당자가 입회하여 이상 유무를 점검·유지하고 그 결과를 부서장이 확인하여야 한다.

제51조의2(비공개 업무자료 처리) ① 비공개 업무자료를 다음 각 호의 어느 하나에 해당하는 방법으로만 처리하여야 한다.

1. 소속 또는 근무중인 기관의 내부망 PC 및 서버에 작성 및 저장·보관

2. 소속 또는 근무중인 기관의 장이 지급한 휴대용 저장매체에 작성 및 저장 · 보관
 3. 소속 또는 근무중인 기관의 장이 자체적으로 구축 · 운용하는 전자우편시스템(이하 "기관 전자우편"), 공무원등이 공동으로 사용할 목적으로 문화체육관광부장관이 구축 · 운용하는 전자우편시스템(이하"공직자통합메일") 및 공무원 등이 다른 공무원등과 자료를 공유하거나 소통하기 위하여 사용하는 전용 소프트웨어(이하"공공 전용 메신저")를 이용한 수 · 발신
 4. 그 밖에 다른 법규에 따라 허용되는 처리방법
- ② 제 1항에도 불구하고 다음 각 호의 어느 하나에 해당하는 경우 소속 또는 근무중인 기관의 장이 지급한 인터넷 PC 또는 출장용 노트북을 이용하여 비공개 업무자료를 처리할 수 있다.
1. 기관 전자우편, 공직자통합메일 또는 공공 전용 메신저의 발신 기능을 이용하여 작성
 2. 기관 전자우편, 공직자통합메일 또는 공공 전용 메신저로 수 · 발신하는 과정에서 일시적 저장
- ③ 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 제2조 제1항 제2호에 따른 정보통신서비스(전자우편 · 메신저 포함) 또는 국외에서 제공하는 이와 유사한 서비스(상용 정보통신서비스)를 이용하여 비공개 업무자료를 처리하여서는 아니된다

제52조(전자정보 저장매체 불용처리) ① 사용자 및 시스템관리자는 하드디스크 등 전자정보 저장매체를 불용처리(교체 · 반납 · 양여 · 폐기 등) 하고자 할 경우에는 정보보안담당관의 승인하에 저장매체에 수록된 자료가 유출되지 않도록 보안조치하여야 한다.

② 자료의 삭제는 해당 정보가 복구될 수 없도록 저장매체별, 자료별 차별화된 삭제방법을 적용하여야 한다.

③ 기관내에서 정보시스템의 사용자가 변경된 경우, 비밀처리용 정보시스템은 완전포맷 3회 이상, 그 외의 정보시스템은 완전포맷으로 저장자료를 삭제하여야 한다.

- ④ 전자정보 저장매체의 불용처리에 관련된 구체적인 사항은 국가정보원 정보시스템 저장매체 불용처리지침에 따른다.

제53조(서버 보안관리) ① 서버 관리자는 서버를 도입 운용할 경우, 정보보안담당관과 협의하여 해킹을 이용한 자료 절취, 위 · 변조 등에 대비한 보안대책을 수립 · 시행하여야 한다.

② 서버 관리자는 서버내 저장자료에 대해 업무별 · 자료별 중요도에 따라 사용자의 접근권한을 차등 부여하여야 한다.

③ 서버 관리자는 사용자별 자료의 접근범위를 서버에 등록하여 인가여부를 식별토록 하고 인가된 범위 이외의 자료접근을 통제하여야 한다.

④ 서버 관리자는 서버의 운용에 필요한 서비스 포트 외에 불필요한 서비스 포트를 제거하며 관리용 서비스와 사용자용 서비스를 분리 운용하여야 한다.

⑤ 서버 관리자는 서버의 관리용서비스 접속시 특정 IP와 MAC주소가 부여된 관리용 단말을 지정 운용하여야 한다.

⑥ 서버 관리자는 서버 설정 정보 및 서버에 저장된 자료에 대해서는 정기적으로 백업을 실시하여 복구 및 침해행위에 대비하여야 한다.

⑦ 서버 관리자는 데이터베이스에 대하여 사용자의 직접적인 접속을 차단하고 개인정보 등 중요정보를 암호화하는 등 데이터베이스별 보안조치를 실시하여야 한다.

⑧ 정보보안담당관은 제1항부터 제7항까지에서 수립한 보안대책의 적절성을 수시 확인하되, 연1회 이상 진단도구를 이용하여 서버 설정 정보 및 저장자료의 절취, 위 · 변조 가능성 등 보안취약점을 점검 할 수 있다.

제54조(홈페이지 게시자료 보안관리) ① 사용자는 개인정보, 비공개 공문서 및 민감 내용 등이 포함된 자료를 홈페이지에 공개하여서는 아니 된다.

② 홈페이지에 정보를 게시하고자 하는 부서장은 사전에 자체 검증을 거쳐 비밀 등 비공개 자료가 게시되지 않도록 하여야 한다.

③ 사용자는 인터넷 블로그 · 카페 · 게시판 · 개인 홈페이지 또는 소셜네트워크 서비스 등 일반에 공개된 전산망에 업무관련 자료를 무단 게재하여서는 아니된다.

④ 정보보안담당관은 소속기관의 홈페이지 등에 비공개용이 게시되었는지 여부를

주기적으로 확인하고 개인정보를 포함한 비공개 자료가 홈페이지에 공개되지 않도록 보안교육을 주기적으로 실시하여야 한다.

⑤ 정보보안담당관은 홈페이지에 중요정보가 공개된 것을 인지할 경우 이를 즉시 차단하는 등의 보안조치를 강구 시행하여야 한다.

제55조(저장매체 관리) ① 분임정보보안담당관은 저장매체가 내장된 정보시스템에 대하여 다음 각 호에 해당하는 경우에는 저장자료를 삭제하여야 한다.

1. 정보시스템의 사용연한이 경과하여 폐기 또는 양여할 경우
2. 정보시스템 무상 보증기간 중 저장매체 또는 저장매체를 포함한 정보시스템을 교체할 경우
3. 정보시스템의 임대기간이 만료되어 반납할 경우
4. 고장 수리를 위한 외부 반출 등 당해 기관이 정보시스템 저장매체를 보안 통제할 수 없는 환경으로 이동이 필요한 경우
5. 기타 정보시스템 사용자 변경 등으로 저장자료 삭제가 필요하다고 판단되는 경우

② 정보시스템 저장자료 삭제 책임은 개인에게 있으며, 지급된 정보시스템의 저장자료는 사용자 본인 책임 하에 삭제하여야 한다. 단, 홈페이지 등 각 부서가 공통적으로 사용하는 정보시스템은 정보보안담당관 책임 하에 저장자료를 삭제하여야 한다.

③ 정보시스템 반출 및 불용 시 다음 각 호에 따라 보안 조치를 하여야 한다.

1. 불용처리 등을 위해 정보시스템을 외부로 반출할 경우 정보보안담당관의 사전 통제를 받아야 하며, 현황을 기록 유지하여야 한다.
2. 정보보안담당관은 저장매체의 고장수리·저장자료 복구 등을 외부에 의뢰할 경우 저장매체에 저장된 자료의 유출 방지를 위해 수리 또는 복구 참여자에 대해 보안서약서 징구·교육 및 기기별 점검내역서 유지 등 필요한 보안조치를 하여야 한다.
3. 정보보안담당관은 정보시스템을 불용 처리할 경우 시스템의 사용기관·부서·사용자 등을 인식할 수 있는 표시를 모두 제거하여야 한다.

④ 저장자료의 삭제는 "[별표 4] 저장매체 자료 삭제 방법"에 따라 조직별 설정

에 맞는 방법을 선택하여야 하며, 정보보안담당관은 정보시스템을 불용 처리할 경우 저장매체 자료 삭제 확인서(별지 제17호 서식)에 따라 저장자료의 삭제 여부를 확인하여야 한다.

⑤ 정보보안담당관은 정보시스템 반출 및 불용처리 시 보안조치 여부를 점검·확인하여야 한다.

제56조(휴대용 저장매체 보안대책) ① 휴대용 저장매체 관리책임자는 휴대용 저장매체를 사용하여 업무자료를 보관할 필요가 있을 때에는 위변조, 훼손, 분실 등에 대비한 보안대책을 강구하여 정보보안담당관의 승인을 받아야 한다.

② 휴대용 저장매체 관리책임자는 휴대용 저장매체를 비밀용, 일반용으로 구분하고 주기적으로 수량 및 보관 상태를 점검하며 반출·입을 통제하여야 한다.

③ 휴대용 저장매체 관리책임자는 USB 관리시스템을 도입할 경우 국가정보원장이 안정성을 확인한 제품을 도입하여야 한다.

④ 휴대용 저장매체 관리책임자는 사용자가 USB메모리를 PC 등에 연결시 자동 실행되지 않도록 하고 최신 백신으로 악성코드 감염여부를 자동 검사하도록 보안 설정한다.

⑤ 비밀자료가 저장된 휴대용 저장매체는 매체별로 비밀등급 및 관리번호를 부여하고 비밀관리기록부에 등재 관리하여야 한다. 이 경우에는 매체 전면에 비밀등급 및 관리번호가 표시되도록 하여야 한다. 다만, 휴대용 저장매체가 국가용 보안시스템에 해당될 경우에는 해당 보안시스템의 운용·관리체계에 따라 관리하여야 한다.

⑥ 휴대용 저장매체를 파기 등 불용처리 하거나 비밀용을 일반용 또는 다른 등급의 비밀용으로 전환하여 사용할 경우 저장되어 있는 정보의 복구가 불가능하도록 완전삭제 프로그램을 사용하여야 한다.

⑦ 정보보안담당관은 사용자의 휴대용 저장매체 무단반출 및 미등록 휴대용 저장매체 사용 여부 등 보안관리 실태를 주기적으로 점검하여야 한다.

제57조(백업 관리) ① 시스템관리자는 정보시스템 및 정보통신망 장애에 대비하여 업무관련 자료와 소프트웨어에 대해 백업 정책을 수립·수행하여야 한다.

② 중요 백업 데이터의 비인가자 접근·유실·훼손에 대비하여 통제구역에 보관

하고 백업 관리대장(별지 제19호 서식)을 비치하여 접근 및 사용제한, 열람 및 사용기록 유지관리 등 보안조치를 하여야 한다.

③ 시스템관리자는 백업 자료에 대해 데이터 및 서비스 회복 테스트를 반기 1회 이상 실시하여 대상 데이터, 서비스, 시간 및 손실 데이터 양 등 세부사항을 기록하고 평가한 후 개선대책을 마련하여야 한다.

제58조(접근기록 관리) ① 시스템관리자는 정보시스템의 효율적인 통제·관리, 사고발생시 추적 등을 위하여 사용자의 정보시스템 접근기록을 유지 관리하여야 한다.

② 제1항의 접근기록에는 다음 각 호의 내용이 포함되어야 한다.

1. 접속자, 정보시스템·응용프로그램 등 접속대상
2. 로그 온·오프, 파일 열람·출력 등 작업 종류, 작업 시간
3. 접속 성공·실패 등 작업 결과 등

③ 시스템관리자는 접근기록을 분석한 결과, 비인가자의 접속 시도, 정보 위변조 및 무단 삭제 등의 의심스러운 활동이나 위반 혐의가 발생한 사실을 발견한 경우 정보보안담당관에게 즉시 보고하여야 한다.

④ 시스템관리자는 정보보안 사고 발생시 확인 등을 위하여 최소 6개월 이상 접근기록을 보관하여야 하며 접근기록 위·변조 및 외부유출 방지 대책을 강구하여야 한다.

제4장 정보통신실 보안

제59조(주요 정보통신 기반시설 등의 보호구역 설정) ① 정보보안담당관은 다음 각 호에 해당하는 경우 주요 정보통신 시설 및 장소를 보호구역으로 설정하여야 한다.

1. 정보시스템실
2. 전산자료 보관실
3. 보안시스템 개발·설치 장소
4. 백업센터 및 중요한 정보통신 기반시설을 집중 제어하는 장소
5. 기타 보안관리가 필요하다고 인정되는 정보시스템 설치 장소

② 정보보안담당관은 제1항에서 지정된 보호구역에 대한 보안대책을 강구할 경우 다음 각 호 사항을 참고하여야 한다.

1. 방재대책 및 외부로부터의 위해 방지대책
2. 상시 이용하는 출입문은 한 곳으로 정하고 이중 잠금장치 설치
3. 출입자 인증·식별 등을 위한 출입문 보안장치 설치 및 주야간 감시대책
4. 휴대용 저장매체를 보관할 수 있는 용기 비치
5. 정보시스템 안전지출 및 긴급파기 계획 수립
6. 관리책임자 및 자료·장비별 취급자 지정 운용
7. 정전에 대비한 비상전원 공급, 시스템의 안정적 중단 등 전력관리 대책
8. 카메라 장착 휴대폰 등을 이용한 불법 촬영 방지 대책 등

③ 정보통신실 관리책임자는 자료보호를 위하여 다음 각 호와 같은 보안대책을 강구하여야 한다.

1. 자료별로 접근권한을 제한
2. 작업은 소관업무에 따라 입력·출력·열람 등으로 제한
3. 열람은 필요에 따라 기본항목·전 항목 등으로 제한

제60조(정보통신실 출입통제 절차) ① 정보통신실의 보안사고 예방을 위하여 모든 출입자는 사전출입인가를 받아야 한다.

② 정보보안담당관은 보안담당자, 시스템관리자 등 업무상 필요하다고 인정하는 자를 정보통신실 상시 출입자 명단(별지 제22호 서식)로 지정하여 업무를 원활히 수행하도록 할 수 있다.

③ 정보통신실 관리책임자는 정보통신실 모든 출입사항을 정보통신실 출입자 관리대장(별지 제23호 서식)에 상세히 기록·유지하여야 한다.

④ 일시적인 출입이 필요한 사람은 출입 인가자와 반드시 동행하며 시스템관리부서의 사전 승인을 득하여야 한다.

⑤ 통제구역 출입 시 사전 승인된 목적 이외의 물품(노트북, 기억매체, 카메라, 카메라 폰, 캠코더 등 영상저장용 장비 등)은 반입할 수 없으며, 이를 어길 경우 근무자는 해당물품을 압수하고 출입자를 통제구역 밖으로 퇴실 시켜야 한다.

제61조(장비 반출입 통제) ① 전산장비의 외부반출이 필요한 경우 시스템관리부서의 장에게 장비반출을 요청한다.

② 시스템관리부서의 장은 반출 전산장비에 내장된 저장매체를 확인하여 "[별표 4] 저장매체 자료 삭제 방법"을 참조하여 해당 저장매체에 저장된 데이터가 복구가능하지 않도록 삭제하도록 하고, 장비반출 및 데이터 삭제 결과를 기록·관리하여야 한다.

③ 저장매체가 있는 전산장비의 유지보수는 전산실내에서 수행하도록 하여 저장매체의 반출을 허용하지 않는다. 다만 정보보안담당관의 사전 승인을 얻은 후 허용할 수 있다.

④ 전산장비의 폐기 시는 제55조(저장매체 보안관리)에 따른다.

제62조(일상점검) ① 정보통신실 담당자는 전산기기 가동 시 일일점검리스트를 작성하여 다음 각 호의 사항을 포함한 전산기기 운용상황을 점검하여 정보통신실 관리자에게 보고한다.

1. 전산실 온도도 정상여부 확인
2. 전원 상태 확인
3. 전산기기의 각 장치별 준비상태 확인

② 공급자가 제공한 장비 보호 사항을 숙지하여야 하며 시스템관리부서는 이를 정기적으로 점검하여야 한다.

③ 시스템관리부서는 일일점검 중 문제점 발견 즉시 시스템관리부서의 장에게 보고 한다.

제63조(예방정비) ① 시스템관리부서는 특별한 경우를 제외하고는 시스템을 안정적으로 운용하기 위하여 매년 하드웨어 예방정비점검계획(P.M : Preventive Maintenance)을 수립하고 매월 1회 이를 실시하여 그 결과를 기록·관리한다.

② 장비는 공급자가 지시한 서비스 기간과 명세에 따라 유지 보수 한다. 각종 장비의 유지 보수를 관리하는 담당자를 지정하고, 외부 유지 보수 서비스의 필요시 절차를 거쳐서 외부 유지 보수 업체를 지정한다. 각종 장비의 유지 보수 이력을 정해진 방법에 따라 기재하고 시스템관리부서의 장에게 확인을 얻어야 한다.

제64조(환경보안) ① 정보통신실 관리자는 전산기기 관리 시 다음 각 호의 사항을 준수하여야 한다.

1. 승인되지 않은 전산기기 부품 해체를 금지함
2. 자성물질고전자파기기를 전산기기 및 자기테이프 등에 접촉하지 않도록 함
3. 전원시설의 예방점검
4. 전기기구를 사용할 때에는 전압을 확인 후 사용
5. 흡연이나 전열기 등 사용금지
6. 소모품 및 출력용지 교체작업, 출력물관리 및 시스템프린터의 상태를 수시 점검
7. 전산기기 전원 작동순서는 공급자의 권고안을 준수하여야 한다.
8. 위험성물질이 보호구역에서 보관되어서는 안 되며, 위험 물질 방치여부를 항상 점검하여야 한다.

② 정보통신실 관리책임자는 주요 전산장비의 안정적인 운영을 위해 "[별표 5] 시설 보안"에 따라 설비하여야 한다.

제5장 정보화용역사업 보안관리

제65조(용역사업 보안관리) ① 정보보안담당관은 정보화·정보보호사업 및 보안컨설팅 수행 등을 외부용역으로 추진할 경우 사업 책임자로 하여금 다음 각 호의 사항을 포함한 보안대책을 수립·시행하도록 하여야 한다.

1. 용역사업 계약시 계약서에 참가직원의 보안준수 사항과 위반시 손해배상 책임 등 명시
2. 용역사업 수행 관련 보안교육·점검 및 용역기간 중 참여인력 임의교체 금지
3. 정보통신망도·IP현황 등 용역업체에 제공할 자료는 자료 인계인수대장을 비치, 보안조치 후 인계·인수하고 무단 복사 및 외부반출 금지
4. 사업 종료 시 외부업체의 노트북·휴대용 저장매체 등을 통해 비공개 자료가 유출되는 것을 방지하기 위하여 복구가 불가능하도록 완전삭제
5. 용역업체로부터 용역 결과물은 전량 회수하고 비인가자에게 제공 및 열람

금지

6. 용역업체의 노트북 등 관련 장비를 반출·반입시 마다 악성코드 감염여부, 자료 무단반출 여부를 확인
- ② 정보보안담당관은 「국가계약법」 시행령 제76조 제1항 제18호에 따라 용역사업 추진 시 과업지시서·입찰 공고·계약서에 다음 각 호의 누출금지 대상정보를 명시해야 하며 해당 정보 누출 시 입찰 참가자격 제한을 위한 부정당업자로 등록 신청을 하여야 한다.
 1. 기관 소유 정보시스템의 내·외부 IP주소 현황
 2. 세부 정보시스템 구성 현황 및 정보통신망 구성도
 3. 사용자계정·비밀번호 등 정보시스템 접근권한 정보
 4. 정보통신망 취약점 분석·평가 결과물
 5. 정보화 용역사업 결과물 및 관련 프로그램 소스코드(유출시 안보·국익에 피해가 우려되는 중요 용역사업에 해당)
 6. 국가용 보안시스템 및 정보보호시스템 도입 현황
 7. 침입차단시스템·방지시스템(IPS) 등 정보보호제품 및 라우터·스위치 등 네트워크 장비 설정 정보
 8. 「공공기관의 정보공개에 관한 법률」 제9조 제1항에 따라 비공개 대상 정보로 분류된 기관의 내부문서
 9. 「개인정보보호법」 제2조 제1호의 개인정보
 10. 「보안업무규정」 제4조의 비밀 및 동 시행규칙 제7조 제3항의 대외비
 11. 그 밖에 각급기관의 장이 공개가 불가하다고 판단한 자료
- ③ 정보보안담당관은 비밀관련 용역사업을 수행할 경우 비밀취급인가, 보안교육 등 보안조치를 수행하여야 한다.
- ④ 정보보안담당관은 제1항부터 제3항까지에서 규정한 보안대책의 시행과 관련한 이행실태를 주기적으로 점검하고 취약요소 발견시 보안하도록 조치하여야 하며, [별표 8, 9] 정보화 용역사업자 보안위규 처리기준 및 정보화 용역사업자 보안 위약금 부과기준에 의거하여 처리할 수 있다.
- ⑤ 용역사업 보안관리 수행을 위하여 필요한 사항은 "위원회 정보화 용역업체 보안관리 매뉴얼"을 따른다.

제66조(계약 시 유의사항) ① 사업관리부서는 계약 체결 시 다음을 포함하여 용역(아웃소싱)업체가 준수하여야 할 정보보안 사항을 계약서에 명문화 한다.

1. 위원회 정보보안관리 지침 준수
2. 계약서의 보안사항 준수에 대한 감사 수감
3. 제공된 내부 자료에 대해 복사 및 외부반출을 할 수 없으며, 업무 완료 후 위원회에 반환
4. 제공된 내부 자료는 외부로 반출할 수 없으며 사업 수행 장소 내에 시전장치가 가능한 보관함에 보관
5. 업무 수행을 위해 반입된 PC는 업무 종료 시까지 반출을 할 수 없으며 다만, 불가피한 경우 위원회의 승인 후 반출
6. 위원회 "USB 등 보조기억매체 관리지침" 준수
7. 업무 수행으로 생산되는 모든 산출물 및 기록은 위원회가 인가하지 않은 자에게 제공·대여·열람을 금지
8. 제공된 자료는 해당 업무 종료 시 반납
9. 사업수행 기간 동안 재해 대비 백업 방안
- ② 사업관리부서는 계약서 내용을 확인·평가하고 필요시 추가적인 통제방안의 명시를 요구하여야 한다.
- ③ 사업 정보보안 방안은 계약서상에 명시하거나 첨부하여야 한다.

제66조의2(계약 특수조건) ① 정보시스템부서장은 「국가를 당사자로 하는 계약에 관한 법률 시행령」 제76조 제1항 제3호다목에 따른 정보통신망 또는 정보시스템 구축 및 유지보수 등의 계약 이행 과정에서 정보통신망 또는 정보시스템에 허가 없이 접속하거나 무단으로 정보를 수집할 수 있는 비인가 프로그램을 설치하거나 그러한 행위에 악용될 수 있는 정보통신망 또는 정보시스템의 약점을 고의로 생성 또는 방지하는 행위 등을 금지하는 내용의 계약 특수조건을 계약서에 명시하여야 하며 계약기간(하자 보증기간 포함) 내에 발생한 보안약점 등에 대해서는 계약업체로 하여금 개선 조치하도록 하여야 한다.

② 필요한 경우 계약업체로부터 제1항과 관련한 행위가 없다는 대표자 명의의

화약서를 요구할 수 있다.

제67조(작업환경 구성) ① 용역(아웃소싱)업체는 사업 수행 장소를 사업 착수 전에 관리부와 사전 협의하여 관리부서가 지정한 장소에서 수행하여야 한다.

② 용역(아웃소싱)업체는 위원회 내부 네트워크를 사용할 수 없도록 자체적인 폐쇄망이나 별도의 인터넷망을 이용하여 네트워크를 사용하도록 네트워크를 구성하는 것을 원칙으로 한다. 단, 정보보안담당관의 승인을 득한 후 사용할 수 있다.

③ 용역(아웃소싱)업체가 내부 네트워크를 사용할 경우 침입차단시스템 등을 이용하여 접근통제가 될 수 있는 환경을 구성한다.

④ PC, 노트북 등의 장비 반입이 필요할 경우 정보보안담당관은 반입되는 장비에 대하여 다음 안전조치에 대한 결과를 확인하고 승인한다.

1. 해당 장비에 대한 백신 프로그램의 설치 및 진단

2. 기타 위원회가 소유한 PC 보안 소프트웨어의 설치

⑤ 개발 프로젝트인 경우 운영환경과 분리된 별도의 개발환경을 구성하여 작업한다.

제67조의2(원격지 개발보안) ① 각 정보시스템부서장은 용역업체가 발주기관 이외 장소(이하 "원격지"라 한다)에서 개발작업(유지보수 제외)을 수행하고자 요청할 경우 관리적·기술적 보안대책을 수립·시행하고 정보화사업 계획단계부터 정보보안담당관에게 보안성검토를 의뢰하여야 한다.

② 용역업체의 원격지 개발과 관련한 보안대책 이행여부를 정기 또는 수시로 점검(불시 점검 포함)하여야 한다.

③ 제2항에 따라 용역업체의 원격지 개발과 관련한 보안대책 이행여부를 점검한 결과 미흡하다고 판단될 경우 원격지 개발 허가를 취소하여야 한다.

④ 용역업체가 발주기관 내 장소에서 개발 작업을 수행하더라도 개발용 서버가 민간 클라우드컴퓨팅서비스를 이용하는 등으로 원격지에 위치할 경우 원격지 개발로 간주하고 보안대책을 수립·시행하여야 한다

제68조(내부시스템 접근통제) ① 용역(아웃소싱)업체는 현재 사용 중인 응용시스템에

대한 입력 및 정정 업무를 수행할 수 없는 것을 원칙으로 한다. 다만, 불가피하게 입력 및 정정 업무가 필요한 경우 용역사업관리 부서장의 사전 승인을 득하여야 한다.

② 용역(아웃소싱)업체에서 위원회 내부시스템(이하 내부시스템이라 한다)을 사용하여 할 경우 계정을 개별적으로 부여하고 시스템에 대한 접근은 다음 각 호의 통제가 적용되도록 한다.

1. 내부시스템 이용시간, 작업지역(IP주소 등)을 제한하여 접근통제를 실시한다.

2. 용역(아웃소싱) 해당 업무에 필요한 정보 및 시스템 이외에 대한 접근은 허용하지 않는다.

3. 발급한 ID의 사용기간을 설정하여 해당기간 이후에는 사용할 수 없도록 한다.

4. 기타 시스템에 대한 접근통제는 본 지침의 보안통제에 준한다.

③ 사업관리부서는 용역(아웃소싱) 계약이 종료된 경우 용역(아웃소싱)업체에서 사용한 모든 시스템 계정을 확인하여 삭제한다.

제69조(시스템 사용 모니터링) ① 용역(아웃소싱)업체의 개발 및 운영과 관련한 서비스에 대해 정보보안담당관은 다음 각 호를 모니터링을 할 수 있다.

1. 시스템 사용 내용 기록·감시

2. PC 및 저장매체 사용 내용 기록·감시

3. 메일, 인터넷 데이터 전송 등 인터넷 및 네트워크 사용 내용 기록·감시

② 사업관리부서는 용역(아웃소싱)업체의 작업 활동에 대해 매주 1회 점검하여 비 인가된 접근행위를 시도하는지 확인한다.

③ 사업관리부서는 비 인가된 시스템 접근시도 또는 사업정보 유출 및 시도 적발 시 해당 사항을 정보보안담당관에게 보고하여야 한다.

제70조(자료유출 방지) ① 사업관리부서는 개인정보 및 민감한 정보를 용역(아웃소싱)업체에 제공한 경우 용역(아웃소싱)업체의 물리적 보안관리 대책(자료 보관·사용·유출방지 대책)을 확인한 후 제공한다.

② 사업관리부서는 사업 진행시 용역(아웃소싱)업체가 수령한 자료는 자료 반·출입 보안조치 관리대장(별지 제13호 서식)에 기록하여 사업 종료 시 회수를 확인한다.

③용역(아웃소싱)업체가 사용한 PC, 노트북 및 저장매체를 확인하여 사업 관련 자료를 확인 삭제한다. 저장매체 삭제의 경우 "제55조(저장매체 보안관리)"에 따른다.

제 6장 안전성 확인

제 1절 보안성 검토

제71조(정보시스템 도입·구축 시 인가 기준) ① 각 정보시스템부서장은 정보화사업을 수행하고자 할 경우 정보화사업과 관련한 보안 대책의 적절성을 평가하기 위하여 사업 계획단계(사업 공고 전)에서 보안성 검토 절차를 이행하여야 한다.

② 각 정보시스템부서장은 업무용시스템 및 홈페이지 등 정보시스템을 도입하기 전에 용역업체 요청, 전문기관(업체) 의뢰, 기관자체 점검 등으로 보안취약점을 미리 확인·제거하고 기록하여야 한다.

제72조(보안성 검토 신청) ① 각 정보시스템부서장은 다음 각 호의 정보화사업을 추진할 경우에 대하여 자체 보안대책을 강구하고 안전성을 확인하기 위하여 사업 계획단계(사업 공고 전)에서 정보보안담당관을 통하여 국가정보원장에게 보안성 검토를 의뢰하여야 한다.

1. 비밀·대외비를 유통·관리하기 위한 정보통신망 또는 정보시스템 구축
2. 국가정보원장이 개발하거나 안전성을 확인한 암호자재를 적용하는 정보통신망 또는 정보시스템 구축
3. 외교·국방 등 국가안보상 중요한 정보통신망 또는 정보시스템 구축
4. 100만명 이상의 개인에 대한 「개인정보보호법」상 민감정보 또는 고유식별정보를 처리하는 정보시스템 구축
5. 주요정보통신기반시설로 지정이 필요한 정보통신기반시설 구축
6. 「국가정보보안기본지침」에 따른 제어시스템 도입

7. 재난관리·국민안전·치안유지·비상사태 대비 등 국가위기 관리와 관련한 정보통신망 또는 정보시스템 구축
8. 국가정보통신망 등 여러 기관이 공동으로 활용하기 위한 정보통신망 또는 정보시스템 구축
9. 행정정보, 국가지리, 환경정보 등 국가 차원의 주요 데이터베이스 구축
10. 정상회의, 국제회의 등 국제행사를 위한 정보통신망 또는 정보시스템 구축
11. 내부망 또는 폐쇄망을 인터넷 또는 다른 정보통신망과 연동하는 사업
12. 내부망과 기관 인터넷망을 분리하는 사업
13. 통합데이터센터·보안관제센터 구축
14. 소속 공무원등이 업무상 목적으로 이용하도록 하기 위한 무선랜, 이동통신망(HSDPA, WCDMA, LTE, 5G 등) 등 구축
15. 원격근무시스템 구축
16. 「클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률」 제20조에 따라 클라우드컴퓨팅서비스제공자의 클라우드컴퓨팅서비스(이하 "민간 클라우드컴퓨팅 서비스"라 한다)를 이용하는 사업
17. 남북 회담 및 협력사업 등을 위한 북한지역 내 정보통신망 또는 정보시스템 구축
18. 외국에 개설하는 사무소 운영을 위한 정보통신망 또는 정보시스템 구축
19. 첨단 정보통신기술을 활용하는 정보화사업으로서 국가정보원장이 해당 기술에 대하여 안정성 확인이 필요하다고 지정하는 사업

② 정보보안담당관은 해당 기관 및 소속기관이 추진하는 다음 각 호에 해당하는 정보화 사업에 대하여 보안성 검토를 실시한다. 다만, 소속기관이 추진하는 제10호부터 제14호까지 해당하는 정보화사업에 대한 보안성 검토는 정보보안내규에 따라 해당 소속기관의 장이 실시하도록 위임할 수 있다.

1. 제1항 단서에 따라 국가정보원장으로부터 보안성 검토를 위임받은 사업
2. 홈페이지 및 웹메일 등 웹기반 정보시스템 구축
3. 인터넷전화시스템 구축
4. 다른 기관의 정보통신망 또는 정보시스템과 연동하여 정보의 소통 또는 서비스를 제공하는 정보시스템 구축

5. 해당 기관의 정보통신망 또는 정보시스템과 분리된 외부인 전용 무선랜, 인터넷망 및 교육장 정보통신망 등 구축
6. 인터넷과 분리된 소속 공무원등의 인사·복지관리 등의 목적을 위한 정보시스템 구축
7. 주요정보통신기반시설 취약점 분석·평가, 정보보안컨설팅 등 용역사업
8. 기존 분리된 내부망·기관 인터넷망 간 자료전송시스템 구축 등 후속사업
9. 대규모 백업·재해복구센터 구축
10. 해당 기관의 정보통신망 또는 정보시스템과 분리된 영상회의시스템 구축
11. 인터넷과 분리된 CCTV 등 영상정보처리기기 구축
12. 백업시스템 구축
13. 대민 콜센터시스템 구축
14. 기타 해당 기관의 장이 필요하다고 판단하는 정보통신망 또는 정보시스템 구축

③ 정보보안담당관은 각 호에 명시된 정보화사업의 경우 보안성 검토 절차를 생략할수 있으나 매뉴얼·가이드라인 등을 준수하는 등 자체 보안 대책을 수립·시행하여야 한다.

1. 1항 및 2항 각 호의 정보화 사업에 해당하지 아니하는 단순 장비·물품 도입
2. 보안성 검토를 거쳐 완료한 정보화사업에 대하여 정보통신망 구성을 변경하지 아니하는 범위 내에서 다음 각 목의 사항을 포함한 후속운영·유지보수·컨설팅(단일 회선의 이중화는 본 호를 적용함에 있어 정보통신망 구성의 변경이 아닌 것으로 본다.)
 - 가. 서버·스토리지·네트워크장비 등 장비 노후화로 인한 단순 장비 교체
 - 나. 전화기·무전기·CCV 등 통신·영상기기의 노후화로 인한 단순 장비 교체
3. 다년도에 걸쳐 계속되는 사업으로써 사업 착수 당시 보안성검토를 완료한 후 사업 내용의 변동 없이 계속 추진하는 운영·유지사업
4. PC·프린터 및 상용 소프트웨어 등 단순 제품 교체

④ 정보보안담당관은 해당 연도의 정보통신망 보안성 검토 대상사업 현황을 매년 1월25일까지 국가정보원장에게 제출하여야 한다.

제73조(보안성 검토 절차) ① 국가정보원장에게 정보통신망 보안성 검토를 의뢰하는 업무 절차는 다음과 같다.

1. 부서장은 정보보안담당관과 협의하여 보안대책을 수립하고 정보보안담당관을 통하여 국가정보원장에게 보안성 검토를 요청한다.
2. 소속기관이 국가정보원에 보안성 검토를 의뢰하고자 할 경우 정보보안담당관과 협의하여 보안대책을 수립하고 소속기관 자체 보안심사위원회 심사를 거친 후 정보보안담당관을 통하여 국가정보원장에게 보안성 검토를 요청한다.

② 정보보안담당관은 제72조(보안성 검토 신청) 제1항에서 명시된 사안을 제외한 경미한 사업을 추진할 경우에 소속기관에 대한 보안성 검토를 수행한다.

③ 정보통신망 보안성 검토는 서면 검토를 원칙으로 하되 **정보보안담당관이** 필요하다고 판단하는 경우에는 현장 확인을 병행 실시할 수 있다.

제74조(제출 문서) ① 정보보안담당관은 국가정보원장에게 보안성 검토를 요청할 경우에는 다음 각 호의 문서를 제출하여야 한다.

1. 사업계획서(사업목적 및 추진계획 포함)
 2. 기술제안요청서(RFP)
 3. 정보통신망 구성도(필요시, IP주소체계 추가)
 4. 자체 보안대책 강구사항
- ② 제1항 제4호의 자체 보안대책 강구사항에는 다음 각 호를 포함하여야 한다.
1. 보안관리 수행체계(조직, 인원) 등 관리적 보안대책
 2. 정보시스템 설치장소에 대한 보안관리 방안 등 물리적 보안대책
 3. 국가용 보안시스템 및 정보보안담당관이 개발하거나 안전성을 검증한 암호 모듈·정보보호시스템 도입 및 운용 계획
 4. 국가기관간 망 연동시 해당 기관간 보안관리 협의사항
 5. 서버, 휴대용 저장매체, 네트워크 등 정보통신망의 요소별 기술적 보안대책
 6. 재난복구 계획 또는 상시 운용계획

제75조(결과 조치) ① 보안성검토를 요청한 부서장은 국가정보원장의 보안성 검토 결과를 준수하여 보안대책을 보완하여야 한다. 이 경우, 정보보안담당관이 보안성 검토 결과 신속한 시정이 필요하다고 판단하는 경우에는 필요한 조치를 요청할 수 있으며 특별한 사유가 없는 한 이에 따라야 한다.

② 정보보안담당관은 정보통신망 보안대책이 적절히 수립되었는지 등 이행여부 확인을 위하여 현장점검을 실시할 수 있다.

제2절 보안적합성 검증

제76조(정보보호시스템의 도입 등) ① 각 정보시스템부서장은 정보 및 정보통신망 등을 보호하기 위해 정보보호시스템을 도입할 경우, [별표 10] 정보보호시스템 유형별 도입요건에 규정된 유형의 시스템에 대해서는 해당 도입요건을 만족하는 시스템을 도입하여야 한다.

② 위원장은 매 반기마다 해당 반기 내에 도입한 제80조에 따른 모든 제품에 대하여 정보통신제품 도입 현황 등을 검증 기관의 장에게 제출하여야 한다.

③ 위원장은 제2항에 따라 관할 하급기관의 장으로부터 제출받은 현황 등을 국가정보원장에게 제출하여야 한다.

제77조(보안적합성 검증 신청) ① 각 정보시스템부서장은 제76조(정보보호시스템의 도입 등)에 따라 정보보호시스템을 도입할 경우 사전에 국가정보원장에게 보안적합성 검증을 신청하여야 한다.

② 보안적합성 검증을 신청하고자 하는 부서의 장은 사전에 정보보안담당관과 협의하여 보안대책을 수립하고 정보보안담당관을 경유하여 국가정보원장에게 보안적합성 검증을 신청한다.

③ 보안적합성 검증대상은 다음 각 호와 같다.

1. 상용 정보보호시스템 등 정보보호를 목적으로 도입·운용하는 정보통신제품
2. 위원회에서 자체 개발하거나 외부업체 등에 의뢰하여 개발한 정보보호시스템
3. 저장매체 소자장비 혹은 완전삭제 소프트웨어 제품
4. L3 이상 스위치, 라우터 등 네트워크 장비

④ 제3항에도 불구하고, 다음 각 호의 경우에는 검증을 생략할 수 있다.

1. 「국가정보화 기본법」 제38조1항 및 같은 법 시행령 제35조에 따라 과학기술정보통신부장관이 정한 정보보호시스템 공통평가기준을 준수한 인증(CC인증) 제도에 따라 국내용 CC인증 또는 국제용 CC인증을 받은 정보통신제품
2. 「소프트웨어산업 진흥법」 제13조에 따른 품질인증(GS인증)을 받은 정보통신제품
3. 「정보보호산업의 진흥에 관한 법률」 제17조에 따른 성능평가를 받은 정보통신제품
4. 「국가표준기본법」 제23조 및 「공인기관 인정제도 운영요령(국가기술표준원 고시) 제3조에 따른 한국인정기구(KOLAS)에 의해 국제표준(ISO/IEC 7025)에 따라 인정받은 시험기관에서 시험한 정보통신제품
5. 국가정보원장이 공정한 검증필 제품목록에 등재된 정보통신제품
6. 국가정보원장이 개발하고 안전성을 확인하여 기술 이전한 정보통신제품

제78조(신청서류) ① 보안적합성 검증을 신청하고자 하는 경우 다음 각 호의 서류(문서)를 제출하여야 한다.

1. 사용 정보보호시스템
 - 가. 별지 제4호 서식의 정보보호시스템 도입시 확인사항 1부
 - 나. 별지 제5호 서식의 보안적합성 검증 신청서 1부
 - 다. 기술제안요청서 사본 1부
 - 라. 제품 설명서(기능·운용 설명서 등)
 - 마. CC 인증서 사본(해당되는 경우)
 - 바. 별지 제24호 서식의 정보보호시스템 보안기능 점검표 1부
 - 사. 별지 제25호 서식의 정보보호시스템 운영 점검사항 1부
2. 자체 개발하거나 외부업체 등에 의뢰하여 개발한 시스템
 - 가. 별지 제4호 서식의 정보보호시스템 도입시 확인사항 1부
 - 나. 별지 제5호 서식의 보안적합성 검증 신청서 1부
 - 다. 기술제안요청서 사본 1부
 - 라. 제품설명서(기능·운용 설명서) 사본 1부

마. 기본 및 상세 설계서(검증기관 또는 시험기관 요청시)

바. 개발완료 보고서 1부

사. 사용설명서 1부

3. 네트워크 장비

가. 별지 제4호 서식의 정보보호시스템 도입시 확인사항 1부

나. 별지 제26호 서식의 네트워크 장비 보안적합성 검증 신청서

다. 장비 설명서(기능·운용설명서, Private MIB 등 포함)

라. 기본 및 상세 설계서(검증기관 또는 시험기관 요청시)

마. 장비 펌웨어 이미지 및 해시값 1부

바. 별지 제27호 서식의 네트워크 장비 도입 최소 보안 요구사항

사. 별지 제28호 서식의 네트워크 변경내용 분석서 1부(도입장비 펌웨어 업데이트 경우)

아. CC인증서 사본(해당되는 경우)

② 각 부서장은 정보보안담당관이 제1항의 제출문서 이외에 보안적합성 검증에 필요하다고 판단하여 추가 자료를 요청할 경우, 특별한 사유가 없는 한 15일 이내에 추가 자료를 제출하여야 한다.

제79조(검증시험 및 결과조치) ① 각 부서장은 정보보안담당관이 시스템 개발업체의 개발환경에 대한 보안관리 실태 점검을 요청할 경우 특별한 사유가 없는 한 협조하여야 한다.

② 각 부서장은 보안적합성 검증결과 취약점을 통보받았을 때에는 30일 이내에 보완대책을 수립하여 조치하고 그 결과를 정보보안담당관에게 통보하여야 한다.

제80조(사후 관리) ① 각 부서장은 보안적합성 검증 완료 이후 시스템에 새로운 취약점이 발견될 경우에는 즉시 제거한 후 그 결과를 정보보안담당관에게 통보하고 제거가 불가능할 경우에는 그 사실을 정보보안담당관에게 통보하여 조치를 받아야 한다.

② 각 부서장은 정보보안담당관이 신규 취약점을 발견한 시스템에 대해 취약점 제거를 요청한 경우 특별한 사유가 없는 한 30일 이내에 이를 제거하고 그 결과

를 정보보안담당관에게 통보하여야 한다.

제81조(무단변경 및 오용금지) 각 부서장은 보안적합성 검증이 완료된 시스템의 형상을 무단 변경하거나 도입 목적 이외의 용도로 운용하기 위해서는 정보보안담당관에게 보안적합성 검증 여부를 확인하여야 한다.

제7장 사이버위협 탐지·대응 및 재난복구 대책

제82조(침해사고 대응체계 구축) ① 정보보안담당관은 「사이버안전 분야」 위기대응 실무매뉴얼을 활용하여 소관분야의 침해사고 대응체계를 구축하고 이행실태를 지속 확인 점검하여야 한다.

② 정보보안담당관은 국가정보원장이 경보 발령시 소관분야 직원을 대상으로 관련 사항을 전파하고 대응조치를 이행하며 진행상황을 예의주시하는 등 대응절차에 따라 신속하게 대처하여야 한다.

③ 정보보안담당관은 제2항에 따른 경보 단계별 조치사항을 국가정보원장에게 통보하여야 한다.

④ 기타 사이버침해사고의 대응에 관한 사항은 「국가사이버안전관리규정」과 「국가사이버안전매뉴얼」에 따른다.

제83조(침해사고 초동조치) ① 정보보안담당관은 소관 정보통신망에 대하여 해킹, 웜·바이러스 유포 등 사이버공격 인지시 피해실태를 파악하고 관련 로그자료 보존 및 필요시 정보통신망 분리 등 초동조치를 하여야 한다.

② 단순 웜·바이러스 감염 등 경미한 사항은 해당 부서장이 자체 처리 후 정보보안담당관에게 관련사항을 통보하여야 한다.

③ 홈페이지 변조, 정보통신망 기능장애·마비 또는 자료 유출 등 중대사고 발생시에는 초동 조치 후 국가정보원장에게 통보하여 지원을 받아야 한다.

④ 제3항과 관련하여 피해 시스템은 사고원인 규명 시까지 증거보전을 의무화하고 임의 자료삭제 또는 포맷을 금지한다.

제84조(사고통보 및 복구) ① 정보보안담당관은 사이버공격으로 인한 사고의 발생

또는 징후를 발견한 경우에는 피해를 최소화하는 조치를 취하고 그 사실을 국가정보원장에게 통보하여야 한다.

② 제1항에서 사이버공격의 사고처리 절차는 다음 각호와 같다.

1. 사고유형 파악
2. 초동조치
3. 기본정보 수집
4. 사고 조사
5. 재발방지 조치

③ 정보보안담당관은 사이버침해사고 결과를 문서화하고 보안사고 원인, 유형, 비용 등을 분석하고 필요시 보안사고 대응절차, 보안대책, 보안정책 등을 변경하는 재발방지 대책을 수립하여야 한다.

④ 정보보안담당관은 유사사고가 반복되지 않도록 침해사고 원인 및 처리결과를 조직내부, 타기관 등과 공유하여야 한다.

제85조(재난복구 대책) ① 정보보안담당관은 인위적 또는 자연적인 원인으로 인한 정보시스템(정보통신망 포함)의 장애(障碍) 발생에 대비하여 해당 정보시스템(정보통신망 포함)의 이원화, 백업관리, 복구 등 종합적인 재난복구 대책을 수립·시행하여야 한다.

② 정보보안담당관은 정보시스템(정보통신망 포함)에 대한 재난복구 대책을 정기적으로 시험하고 검토해야 하며 업무 연속성에 대한 영향평가를 실시하여야 한다.

③ 정보보안담당관은 정보시스템(정보통신망 포함)의 장애에 대비한 백업시설을 확보하고 정기적으로 백업을 수행하여야 하며 백업시설을 설치할 경우에는 정보시스템실과 물리적으로 일정거리 이상 위치한 안전한 장소에 설치하여 재난에 대비하여야 한다.

④ 정보보안담당관은 제3항에 따른 백업시설을 설치할 경우에는 정보통신실과 물리적으로 일정거리 이상 떨어진 안전한 장소에 설치하여야 하며 전력공급원 이원화 분리 등 정보시스템의 가용성을 최대화 할 수 있도록 하여야 한다.

제86조(모의훈련) ① 정보보안담당관은 자체 정보통신망을 대상으로 매년 정기 또는 수시 사이버위기 대응 모의훈련을 실시하여야 하고, 훈련결과를 국가정보원장에

게 통보하여야 한다.

② 정보보안담당관은 모의훈련 결과 시정이 필요하다고 판단되는 경우에는 각 부서장에게 필요한 조치를 요청할 수 있다. 이 경우 각 부서장은 특별한 사유가 없는 한 필요한 조치를 이행하여야 한다.

제8장 사고처리

제87조(정보보안 사고조사) ① 정보보안담당관은 "[별표 제7]정보보안 사고 유형"에서 규정한 사고가 발생한 때에는 즉시 피해를 최소화하도록 조치를 취하고 다음 각 호의 사항을 국가정보원장에게 통보하여야 한다.

1. 일시 및 장소
2. 사고 원인, 피해현황 등 개요
3. 사고자 및 관계자의 인적사항
4. 조치내용 등

② 정보보안담당관은 규정에 따른 관련자 징계, 재발방지를 위한 보안대책의 수립·시행 등 사고 조사 결과에 따라 필요한 조치를 하여야 한다.

제88조(보안 규정 위반자 처벌) 제87조(정보보안 사고조사), 보안감사, 정보보안진단 및 보안관리 실태 평가 과정에서 발견된 보안 규정 위반자에 대한 처벌은 "공무원 징계령 시행규칙" 및 "위원회 정보보안 위반 감점기준" 등에 따른다.

부 칙

제1조(시행일) 이 훈령은 발령한 날부터 시행한다.

별 표

[별표 1] 교육대상자 별 교육내용

교육대상자	교육내용
부서 보안담당자	- 정보보안 관련 지침 및 매뉴얼 - 최신 해킹 동향 및 기법 - 해킹원리 및 해킹방지 도구, 보안프로그램 소개 및 적용방안 - 해킹사고시 초동조치 방법 - 기타 보안관련 내용
정보시스템 관리자, 운영자, 개발자 및 유지보수자	- 운영체계, 네트워크, 데이터베이스 보안취약점 - 웹환경 및 웹을 이용한 보안취약점 공격 기법 - 정보보안 관련 지침 및 매뉴얼 - 최신 해킹 동향 및 기법 - 해킹사고시 초동조치 방법
전 직원	- 최신 해킹 동향 및 기법 - PC 보안 교육 - 인터넷, 이메일 보안교육 - 소프트웨어 보안 교육 - 해킹사고시 초동조치 방법

[별표 2] 정보보안 점검표

2.1. 정보보안 기본활동

순번	세부 점검사항	비고
1	기관 자체 실정에 맞는 정보보안업무 내규를 수립하고 있는가?	
2	매년 정보보안업무 활동계획을 수립·시행하고 심사분석 하는가?	
3	정보보안업무 전담 조직 및 직원(정보보안담당관)이 지정되어 있는가?	
4	소속·산하기관 대상 정보보안 감사·점검·지도방문을 실시하는가?	
5	소속·산하기관 대상 정보보안 교육을 실시하고 있는가?	
6	사이버보안진단의 날을 내실 있게 수행하는가?	
7	정보보안 사고, 정보통신망 장애 발생시 보고체계 및 조치절차가 있는가?	
8	정보시스템 사용자에 대한 심사 등 인적보안 절차·방법을 강구중인가?	
9	보직변경 등 인사이동시 정보시스템 접근권한을 신속하게 조정하는가?	
10	서버·PC 등 정보시스템 현황을 제대로 파악하는가?	
11	정보통신장비(노트북 등) 반출입 통제를 철저히 하는가?	
12	업무자료를 상용 전자우편으로 전송하고 있지 않는가?	
13	정보통신망 구축 및 유지보수 업무를 수행하는 외부인력에 대한 신원확인 및 보안서약서 징구 등 충분한 보안조치를 하고 있는가?	
14	용역업체 직원의 내부 정보시스템 접근을 통제하고 있는가?	
15	홈페이지에 자료 게재시 자체 보안성 검토를 시행하고 있는가?	
16	중요 정보화사업에 대하여 국가정보원에 보안성 검토를 의뢰하는가?	
17	정보보호시스템(암호모듈 포함) 도입시 보안적합성 검증절차를 준수하는가?	
18	비밀을 전자적으로 처리할 경우 국가용 보안시스템으로 암호화하는 등 규정을 준수하는가?	

2.2. PC 및 서버 보안관리

순번	세부 점검사항	비고
1	PC·서버에 설치된 운영체제 및 응용프로그램을 최신 보안업데이트 하였는가?	
2	백신프로그램이 자동 업데이트되고 실시간 감시기능이 설정되어 있는가?	
3	인터넷 PC에 업무관련 자료(비밀 포함)을 보관하고 있는가?	
4	업무용 PC에 비밀이 평문으로 저장되어 있는가?	
5	P2P, 웹하드, 메신저 등 업무에 무관한 서비스가 허용되거나 비인가 프로그램을 사용하지 않도록 보안조치 하는가?	
6	비인가자 접근방지를 위하여 PC 부팅 비밀번호를 설정했는가?	
7	서버내 저장자료는 중요도에 따라 권한설정이 되어 있는가?	
8	공개서버가 DMZ 구간에 위치하는 등 정보통신망 구성측면에서 PC 및 서버 등의 위치가 적정한가?	
9	인가받지 않은 휴대용 저장매체(USB메모리, 이동형 하드디스크, 메모리카드 등)를 반입·휴대하고 있는가?	
10	전자우편 비밀번호 설정시 특수문자 포함, 9자리 이상으로 설정하고 주기적으로 변경 사용하는가?	
11	비밀은 비밀용 USB메모리를 별도 지정하여 보관하고 비밀관리기록부에 등재하여 사용하고 있는가?	
12	서버 등 정보시스템 접근기록을 유지 관리하는가?	
13	PC·서버에 비인가 USB메모리 등 비인가 정보통신기기 연결시 작동되지 않도록 보안 설정되어 있는가?	
14	PC·노트북 등 저장매체가 있는 기기의 고장시 저장된 자료의 완전 삭제를 확인하고 외부에 수리를 의뢰하는가?	
15	중요정보가 저장된 매체 불용처리시 전용 소자장치로 삭제하거나 파쇄·용해 등 물리적으로 완전 파기하고 있는가?	

2.3. 네트워크 보안관리

순번	세부 점검사항	비고
1	정보시스템 세부 구성도(IP 포함)를 최신으로 유지하면서 대외비 이상 비밀로 관리하고 있는가?	
2	업무자료를 소통하기 위한 내부망은 인터넷과 분리 운영하는가?	
3	업무망·인터넷간 자료공유 방안이 적정한가?	
4	업무자료를 소통하기 위한 내부망 구축시 사설주소체계(NAT)를 적용하는가?	
5	국가정보원장이 안전성을 검증한 정보보호시스템을 운용하고 있는가?	
6	네트워크를 통한 파일공유를 제한하고 있는가?	
7	스위치·라우터 등 네트워크 장비와 서버는 비인가자가 접속 못하도록 IP·MAC통제 등 보안설정하고 불필요한 서비스포트를 제거하는가?	
8	와이브로, 무선랜 등 허가받지 않은 인터넷 접속경로가 존재하는가?	
9	첨단 정보통신기기에 의한 내부 업무자료 유출방지 대책이 충분한가?	
10	시스템 최초 설치시 등록된 관리자계정(회사명 등)·패스워드를 변경하였는가?	
11	장비 신규 도입, IP할당내역 등 전산망 구성 변동시 관련사항을 기록하는가?	
12	중요업무 처리 PC는 인터넷 연결을 금지하고 이상 유무를 수시로 점검하는가?	
13	무선네트워크 구축시 사전에 국가정보원의 보안성검토를 받았는가?	
14	홈페이지에 대한 보안취약점을 주기적으로 점검하는가?	
15	불가피한 사정상 무선중계기를 설치하였을 경우 WPA2이상 보안설정을 하였는가?	
16	직원의 태백·파견·이동근무 등 원격근무시 보안관리 절차가 충분한가?	
17	제어시스템을 독립망으로 운영하는가?	
18	(제어정보를 OA망으로 전달할 경우) 제어망 → OA망으로 일방향 통신을 하는가?	

2.4. 정보통신시설보안 및 대도청 활동

순번	세부 점검사항	비고
1	제어시스템이 인터넷과 분리 운영되는 등 제어정보망 보안관리가 양호한가?	
2	주요정보통신기반시설의 보안취약점을 주기적으로 분석·평가하는가?	
3	주요정보통신기반시설 취약점 분석·평가 세부결과를 중요자료로 관리하는가?	
4	인위적·자연적 원인에 따른 정보통신망 장애 대비 백업 등 재난방지 대책을 강구하였는가?	
5	통합전산센터, 정보통신실 등 중요 정보통신시설을 보호구역으로 관리하는가?	
6	사무실 책상서랍 등에 비밀문건이나 비인가 정보통신기가 방치되어 있는지 주기적으로 확인하는가?	
7	외부인의 정보통신실 출입이 통제되고 관련기록이 관리되는가?	
8	무정전 전원공급장치 설치 등 비상시 전력장애에 대한 대책을 강구하고 있는가?	
9	침입자동 경보장치, CCTV 등 보안장비와 방화장비(하론소화기 등) 정상동작 여부를 정기적으로 점검하고 있는가?	
10	정보통신시설에 관련시스템 긴급 파기를 위한 장비(해머 등)를 비치하였는가?	
11	정보통신시설에 대한 접근권한을 업무목적에 따라 차등 적용하고 있는가?	
12	외부인이 청사내 출입할 경우 출입통제를 실시하고 있는가?	
13	주기적으로 대도청 측정활동을 실시하는가?	
14	통신(전화 등)단자함에 시간장치를 하여 비인가자가 무단 접근할 수 없도록 조치되어 있는가?	
15	중요 정보통신장비 수리·점검시 정보보안담당관이 입회하고 있는가?	
16	중요한 회의에는 무선전화기, 무선마이크, 인터콤 등 도청에 취약한 무선 통신 기기 사용을 통제하고 있는가?	

2.5. 암호장비 · 논리, 보안자재 관리

순번	세부 점검사항	비고
1	암호장비 · 논리, 보안자재 등을 소통 기준에 맞게 운용하고 있는가?	
2	암호장비 · 보안자재의 보유현황 및 동작 상태를 주기적으로 확인하는가?	
3	‘국가용 보안시스템 점검기록부’ 를 비치, 월1회 이상유무를 기록하고 정보보안 담당관은 점검여부를 확인하고 있는가?	
4	암호장비 · 보안자재의 정 · 부책임자 교체시 인계인수를 실시하고 국가용 보안 시스템 관리기록부에 인계인수 사항을 기록하는가?	
5	암호실은 출입을 통제하고 그 내용을 기록 유지하고 있는가?	
6	암호장비 · 보안자재는 취급책임자가 직접 운반하고 이를 확인하기 위하여 국가용 보안시스템 증명서를 사용하고 있는가?	
7	암호장비의 암호체계, 키 운용체계 관련서류 등 결과물을 비밀로 관리하는가?	
8	암호장비의 고유명칭, 제원 및 대상국소, 수량 등 운용현황이 기록된 문서는 대외비 이상으로 분류 관리하는가?	
9	노후 등으로 사용하지 않는 암호장비를 방치하고 있지는 않는가?	
10	未승인 보안제품이나 외국에서 생산한 보안제품을 무단 사용하는가?	
11	암호장비 설치시 분실 · 도난 등 보안사고 방지대책을 강구하고 있는가?	
12	암호장비가 설치된 랙 덮개는 시건장치를 하고 잠금 여부를 수시로 확인하는가?	
13	암호장비 설치 후 30일 이내에 국가정보원장에게 암호장비 운용현황을 등록하는가?	
14	보안자재 취급이 필요한 자에 대하여 암호자재 및 음어자재 취급을 인가하고 관련 업무 수행자는 인감등록을 실시하는가?	
15	암호자재는 암호실내 금고, 음어 · 약호자재는 시건된 별도함에 보관하는가?	
16	현용을 제외한 미래용, 사용완료 보안자재는 봉인하여 보관하고 있는가?	
17	사용기간이 만료된 보안자재는 국가정보원과 협의하여 처리하고 있는가?	
18	암호논리 적용시 국가정보원장이 안전성을 검증한 것을 사용하는가?	
19	암호취급자는 정보시스템 등에 암호논리를 적용하는 쉘 과정을 감독하고 용역 업체 등에 대해서는 보안서약서 징구 등 보안대책을 강구하는가?	

2.6. 보안관제 등 해킹 대응활동

순번	세부 점검사항	비고
1	사이버공격에 대응하기 위한 관제센터를 운영하거나 同 업무를 he기관에 위탁 하였는가?	
2	보안관제센터 운영을 총괄 관리하는 전담 공무원이 있는가?	
3	사이버공격 탐지 · 대응 매뉴얼이 구비되어 있는가?	
4	해킹사고 조사결과, 보안위규자에 대한 처벌이 제대로 이루어지고 있는가?	
5	보안시스템 및 정보시스템에 대한 로그를 일정기간 유지하고 있는가?	
6	보안관제 용역업체 직원에 대한 보안대책이 있는가?	
7	자체 DDoS공격 대응매뉴얼을 구비하였는가?	
8	자체 사이버위기 대응 모의훈련을 주기적으로 실시하는가?	
9	DDoS공격 등 침해사고 발생시 국가정보원 등 유관기관에 즉시 연락하는가?	
10	시스템 장애시 유지보수 업체에 연락할 수 있는 비상연락체계가 구비되어 있는가?	
11	보안관제시스템에 대한 물리적인 보안대책을 준수하고 있는가?	
12	침해사고 발생시 사고조사내역 등 관련 문서(전자문서 포함)를 저장하고 있는가?	
13	해킹메일 대응방안 등 침해사고 대응절차 등을 보안교육을 수행하는가?	
14	보안취약점 발표시, 대상기관이나 담당직원에게 즉시 배포하는가?	
15	국가사이버안전센터 등과 사이버위협정보, 탐지기술 등 정보를 공유하고 있는가?	
16	사이버공격 발생시 소속 · 산하기관에 전파할 수 있는 체계가 구비되었는가?	

[별표 3] PC 보안 설정

구분	보안기능	설명
패스워드 관리	패스워드 강제 변경 설정	일정 주기마다 강제로 패스워드 변경하게 하는 기능(최소 1개월에 1회 이상)
	패스워드 최소자리 규정	최소 패스워드 자리를 규정하는 기능(9자리 이상)
	패스워드 조합 통제기능	- 영문/숫자/특수문자 혼용사용
		- 이전 패스워드 재사용 금지
		- ID와 같은 패스워드 금지
	패스워드 화면표시 금지	- 유추 가능한 패스워드 사용 금지(연속번호, 동일숫자, 동일한 영문자 주민번호, 전화번호 등)
		사용자 비밀번호는 화면 및 출력물에 노출되어서는 안 된다.
접근통제	강화된 사용자 인증	사용자 신분을 사용자의 휴대물, 생체 및 인증서 등을 확인하여 인증하는 기능
	CMOS 패스워드 설정	CMOS 패스워드를 설정하여 부팅 시 비인가자의 접근을 통제하는 기능
	관리자 패스워드 설정	PC Administrator 패스워드를 설정하여 비인가자의 접근을 통제하는 기능
바이러스 및 악성코드 방지	화면보호기 설정	장시간 자리를 비울 경우 비인가자의 접근을 통제하기 위한 화면보호기 설정기능(10분 이내)
바이러스 및 악성코드 방지	바이러스 및 악성코드 방지 설정	바이러스 및 악성코드를 예방, 탐지, 제거할 수 있는 기능
침입차단	개인PC 방화벽 설정	PC 자체에 각 서비스 포트별 침입차단기능
PC 통합 보안	PC보안관리 설정	바이러스백신, PC보안도구 설치, 보안 업데이트 등을 중앙에서 모니터링하는 기능
	매체 제어 설정	USB메모리, CD/DVD 등의 저장매체 저장을 중앙에서 모니터링하는 기능
	자료 유출 모니터링 설정	메일, 인터넷 게시판 등을 사용하여 내부 정보를 외부에 전송하는 활동을 중앙에서 모니터링하는 기능

[별표 4] 저장매체 자료 삭제 방법

< 저장매체 · 자료별 삭제 방법>

저장매체 \ 저장자료	공개자료	민감자료 (개인정보 등)	비밀자료 (대외비 포함)
플로피디스크	①	①	①
광디스크 (CD-DVD 등)	①	①	①
자기 테이프	①·②중 택일	①·②중 택일	①
반도체메모리 (EEPROM 등)	①·③중 택일	①·③중 택일	①·③중 택일
	완전포맷이 되지 않는 저장매체는 ① 방법 사용		
하드디스크	④	①·②·③중 택일	①·②중 택일

① : 완전파괴(소각 · 파쇄 · 용해)

* 비밀이 저장된 플로피디스크 · 광디스크 파쇄시에는 파쇄조각의 크기가 0.25mm 이하가 되도록 조치

② : 전용 消磁장비 이용 저장자료 삭제

* 소자장비는 반드시 저장매체의 磁氣力보다 큰 磁氣力 보유

③ : 완전포맷 3회 수행

* 저장매체 전체를 '난수' · '0' · '1'로 각각 중복 저장하는 방식으로 삭제

④ : 완전포맷 1회 수행

* 저장매체 전체를 '난수'로 중복 저장하는 방식으로 삭제

[별표 5] 시설 보안

구 분	시설보안 아키텍처	통제 구역
누수감지기	물의 누수로 인한 전산장비 훼손을 방지하기 위해 주요 지점에 누수감지장치를 설치	적용
화재감지기	화재발생을 감지할 수 있는 설비	적용
소화설비	화재발생시 조기 진화할 수 있는 소화설비	적용
항온 항습기	적절한 용량의 항온항습기 등이 설치되어 환기, 습도, 먼지로부터 보호됨	적용
무정전 전원 공급장치	전원공급 이상 및 전압불안정을 보호하기 위한 UPS	적용
자가발전기	전원중단 시 자체적으로 전력을 공급하기 위한 자가발전 시설	선택적용
전원공급라인 이중화	전력공급 라인을 이중화 하여 한쪽 전력라인의 손상 시 사용한 백업라인 확보	선택적용
케이블 보호	전력 및 통신 회선이 도청이나 손상으로부터 보호하기 위한 케이스 및 바닥과 Floor의 이격공간	적용
전력선과 거리 이격	전력선과 통신선의 상호간섭 방지를 위한 거리유지	적용

[별표 6] 정보자산 분류

6.1 응용시스템 중요도 결정 요소

응용시스템의 중요도는 사용자 규모 및 대상, 업무관련성, 정보중요성의 3가지 요소를 고려하여 결정한다. 각 요소의 세부 구분별로 배점을 다음과 같다.

중요도 평가영역	세부구분	배점
사용자 규모 및 대상	위원회 전체 직원	5
	위원회 일부직원, 외부기관 및 대국민(업무상)	5
	위원회 일부 직원, 대국민(홍보용)	3
	대국민(홍보용)	1
정보시스템 의존도	전체 업무 대비 정보시스템 의존 비율 75%초과	5
	전체 업무 대비 정보시스템 의존 비율 50~75%	3
	전체 업무 대비 정보시스템 의존 비율 50%미만	1
정보의 중요도	국가안전보장, 비밀, 통일정책 등 국가안보 및 국민 생활에 피해를 미치는 정보	5
	업무정보	3
	공개정보	1

6.2 응용시스템 중요도 결정

가. 응용시스템의 중요도는 응용시스템 중요도 결정요소의 합을 산술평균하여 다음의 기준에 따라 “가”, “나”, “다”급으로 구분한다.

응용시스템 중요도 등급	기준	설명
가	3.7 ~ 5점	매우 중요
나	2.4 ~ 3.6점	중요
다	1 ~ 2.3점	보통

나. 분류된 응용시스템은 다음 각 호의 사항을 고려하여 등급을 보정한다.

- 응용시스템 사용자의 특성(예 : 위원회 인터넷, 전자결재 등)
- 응용시스템의 대표성(예 : 중요도 등급이 낮더라도 장애발생 시 위원회 정보시스템 신뢰성에 손상을 가하는 경우)
- 기타 관계법규 및 보안지침에 특별히 규정하는 사항

6.3 정보자산 중요도 결정

정보자산의 중요도는 해당 정보자산이 운용하는 응용시스템의 중요도에 준한다.

정보자산 중요도 등급	기준
가	“가” 급 응용시스템을 운용하는 서버, 네트워크 장비, 스토리지, 백업장비
나	“나” 급 응용시스템을 운용하는 서버, 네트워크 장비, 스토리지, 백업장비
다	“다” 급 응용시스템을 운용하는 서버, 네트워크 장비, 스토리지, 백업장비

[별표 7] 정보보안 사고 유형

조	내 용	항	세 부 내 용
1	전자정보 (전자문서 및 전자기록물)	(1) (2) (3) (4)	비밀의 유출 주전산기(주요서버 등)대용량 전자기록(DB) 손괴 전자정보의 위조변조훼손 및 유출 PC 등 단말기 비밀의 평문 보관 및 유통
2	정보시스템 및 정보통신실	(1) (2) (3) (4) (5) (6) (7)	정보통신망에 대한 해킹·악성코드의 유포 비밀이 저장된 PC, 보조기억매체 등 분실 정보시스템 및 정보통신실 파괴 고의적인 중요 정보시스템 기능 장애 및 정지 상용메일 등을 통한 비밀 등 중요자료 무단 소통 비밀 등 중요자료의 무단 반출 정보통신기기를 통한 비밀 등 중요자료 무단 소통
3	암호장비	(1) (2) (3) (4) (5) (6)	암호장비 분실 및 피탈 암호장비 파손 및 임의파기 암호장비 복제·복사 비인가 암호장비 사용 암호장비 비닉체계 특성 및 제원 노출 암호장비 키 운용체계 노출
4	보안자재	(1) (2) (3) (4)	암호음어·약호자재의 분실 및 누설 암호음어·약호자재의 파손 및 임의파기 암호음어·약호자재의 임의제작 사용 세부 암호체계 노출

[별표 8] 정보화 용역사업자 보안위규 처리기준

구 분	위 규 사 항	처리 기준
심 각	1. 비밀, 대외비급 정보 유출 및 유출 시도 가. 정보시스템에 대한 구조, 데이터베이스 등의 정보 유출 나. 개인정보.신상정보 목록 유출 다. 비공개 항공사진.공간정보 등 비공개 정보 유출 2. 정보통신시스템에 대한 불법적 행위 가. 관련 시스템에 대한 해킹 및 해킹 시도 나. 시스템 구축 결과물에 대한 외부 유출 다. 시스템내 인위적인 악성코드 유포	. 사업참여 제한 (부정당업체 등록) . 위규자 및 직속 감독자 등 중징계 . 재발발지를 위한 조치계획 제출 . 위규자 대상 특별 보안교육 실시 및 결과 제출
중 대	1. 비공개 정보 관리 소홀 가. 비공개 정보를 책상위 등에 방치 나. 비공개 정보를 휴지통.폐지함 등에 유기 또는 이면지 활용 다. 개인정보.신상정보 목록을 책상 위 등에 방치 라. 기타 비공개 정보에 대한 관리 소홀 2. 사무실.보호구역 보안관리 허술 가. 통제구역 출입문을 개방한 채 퇴근 나. 인가되지 않은 작업자의 내부 시스템 접근 다. 통제구역내 장비.시설 등 무단 사진 촬영 3. 전산정보 보호대책 부실 가. 업무망, 인터넷망을 혼용사용, 보안USB 사용 규정 위반	. 위규자 및 직속 감독자 등 중징계 . 재발발지를 위한 조치계획 제출 . 위규자 대상 특별 보안교육 실시 및 결과 제출

구 분	위 규 사 항	처리 기준
	나. 웹하드.P2P 등 인터넷 자료공유 사이트를 활용하여 용역사업 관련 자료 수발신 다. 개발.유지보수 시 원격작업 사용 라. 저장된 비공개정보 패스워드 미부여 마. 인터넷망 연결 PC 하드디스크에 비공개 정보 저장 바. 외부용 PC를 업무망에 무단연결 사용 사. 보안관련 프로그램 강제 삭제 아. 사용자 계정관리 미흡 및 오남용(시스템 불법 접근 시도 등)	
보 통	1. 국민권익위원회 제공 중요정책.민감 자료 관리 소홀 가. 주요 현안.보고 자료를 책상위 등에 방치 나. 정책.현안 자료를 휴지통.폐지함 등에 유기 또는 이면지 활용 2. 사무실 보안관리 부실 가. 캐비넷.서류함.책상서랍 등을 개방한 채 퇴근 나. 출입키를 책상위 등에 방치 3. 보호구역 관리 소홀 가. 통제.제한구역 출입문을 개방한 채 근무 나. 보호구역내 비인가자 출입허용 등 통제 미실시 4. 전산정보 보호대책 부실 가. 휴대용 저장매체를 미시건 서랍, 책상위 등에 방치한 채 퇴근 나. 네이트온 등 비인가 메신저 무단 사용 다. PC를 켜놓거나 보조기억매체(CD, USB 등)을 꽂아놓고 퇴근	. 위규자 및 직속 감독자 등 경징계 . 위규자 및 직속 감독자 사유서 및 경위서 제출 . 위규자 대상 특별 보안교육 실시 및 결과 제출

구 분	위 규 사 항	처리 기준
	라. PC, 노트북 부팅.윈도우.화면보호 패스워드 미설정 또는 "1111"등 단순 숫자 부여 마. PC, 정보시스템 등 전산장비 사용자계정 또는 패스워드를 모니터 옆 등 외부에 노출 바. 비인가 보조기억매체 무단 사용 5. 인원 보안관리 위반 가. 사전 승인받지 않고 사업 투입인력 임의 교체 나. 출입증 분실 시 24시간 내 보고 불이행	
경 미	1. 업무 관련 서류 관리 소홀 가. 진행중인 업무 자료를 책상 등에 방치, 퇴근 나. 복사기, 인쇄기 위에 서류 방치 2. 근무자 근무상태 불량 가. 각종 보안장비 운용 미숙 나. 출입문 열쇠의 분실 시 24시간내 보고 또는 48시간내 교체 불이행 3. 전산정보 보호대책 부실 가. 보안 소프트웨어(백신, 내PC 지키미 등) 주기적 점검 미실시 나. PC내 보안성이 검증되지 않은 프로그램 사용	· 위규자 서면구두 경고 등 문책 · 위규자 사유서 및 경위서 제출

[별표 9] 정보화 용역사업자 보안 위약금 부과기준

구 분	위규 수준			
	A급	B급	C급	D급
위규	심각 1건	중대 1건	보통 2건 이상	경미 3건 이상
위약금 비중	부정당업자등록	총사업비의 00%	총사업비의 00%	총사업비의 00%

※ 위약금 규모는 사업규모에 따라 사업담당자가 조정

※ 보안 위약금은 다른 요인에 의해 상쇄, 삭감되지 않도록 부과

[별표 10] 정보보호시스템 유형별 도입요건

시스템 유형	도입 요건	비 고
침입차단시스템	CC인증(EAL2이상)	
침입탐지시스템	CC인증(EAL2이상)	
침입방지시스템	CC인증(EAL2이상)	
보안관리서버	CC인증(EAL2이상)	
통합보안관리	CC인증(EAL2이상)	검증필 암호모듈 탑재필요(VPN기능)
웹방화벽	CC인증(EAL2이상)	
DDoS 대응장비	CC인증(EAL2이상)	
VoIP 방화벽	CC인증(EAL2이상)	
무선 침입방지시스템	CC인증(EAL2이상)	
가상사설망	CC인증(EAL2이상)	검증필 암호모듈 탑재필요
네트워크접근제어시스템	CC인증(EAL2이상)	
스팸메일차단제품	CC인증(EAL2이상)	
바이러스 백신	CC인증(EAL2이상)	
무선랜 인증시스템	CC인증(EAL2이상)	
PC용 침입/차단제품	CC인증(EAL2이상)	
웹기반 콘텐츠 보안제품	CC인증(EAL2이상)	
자료유출방지시스템	CC인증(EAL2이상)	
PC 매체제어 제품	CC인증(EAL2이상)	
서버보안제품	CC인증(EAL2이상)	
DB 접근통제 제품	CC인증(EAL2이상)	
다중영역구분 보안제품	CC인증(EAL2이상)	
스마트카드제품	CC인증(EAL4이상)	
USB 관리시스템	CC인증(EAL2이상)	검증필 암호모듈 탑재필요
완전삭제제품(복합기능)	CC인증(EAL2이상)	
PKI 제품	국가용 암호제품	검증필 암호모듈 탑재필요
문서 암호화 제품	국가용 암호제품	검증필 암호모듈 탑재필요
DB 암호화 제품	국가용 암호제품	검증필 암호모듈 탑재필요
디스크, 파일 암호화 제품	국가용 암호제품	검증필 암호모듈 탑재필요
메일 암호화 제품	국가용 암호제품	검증필 암호모듈 탑재필요
구간 암호화 제품	국가용 암호제품	검증필 암호모듈 탑재필요
키보드보안 제품	국가용 암호제품	검증필 암호모듈 탑재필요
문서 위변조 방지제품	국가용 암호제품	검증필 암호모듈 탑재필요
일회용 패스워드	국가용 암호제품	검증필 암호모듈 탑재필요
통합인증 제품	국가용 암호제품	검증필 암호모듈 탑재필요

* 상기 표에 따라 CC인증을 받은 정보보호시스템을 도입하였다고 할지라도 CC인증을 받지 않은 보안기능을 사용하지 않도록 조치 필요

[별표 11] 정보보안 위규자 처리규정

구 분	위 규 사 항	처리 기준
심 각	가. 정보화 관련 자료 또는 정보 무단유출 가. 정보시스템 해킹 등 불법적 접근 나. 전산실 등 통제구역 무단 침입 다. 정보화 장비 및 네트워크 등의 불법 사용 라. 상용메일, 클라우드 서비스 등을 통한 업무 자료 전송에 따른 자료유출 사고 발생 마. 기타 정보화 관련 규정 위반 및 사용자 부주의에 의한 정보보안 사고 발생	· 징계위원회 회부 (*공무원 징계령 시행규칙에 근거)
보 통	나. 비인가 SW 무단설치 다. 상용메일 등을 통한 업무자료 공유·전송 라. 이동식 저장매체 사용 규정 위반 마. 정보시스템 계정 등의 불법 사용 바. 보안USB 분실 및 고의적 훼손 사. 기타 정보보안 관련 규정 위반	· 위규자 사유서 및 경위서 제출
경 미	가. 사이버보안 진단의 날(내PC지킴이) 미 수행 나. PC 패스워드 및 화면보호기 미 설정 다. OS 및 백신 등 SW 업데이트 미흡 라. 인터넷망 PC에 업무자료 저장 마. 일반 이동식저장매체 저장문서 암호 미설정	· 위규자사면·구두 경고

별지 서식

[별지 제1호 서식]

정보보안업무 세부 추진계획

1. 활동 목표

2. 기본 방침

3. 세부 추진계획

분야별	사업명	세부 추진계획	주관·관련부서	비 고

※ 국가정보원 보안성검토 대상여부 표기

4. 전년도 보안감사·지도방문시 도출내용과 조치내역

도출 내용	조치 내역	담당부서

※ 형식위주의 계획수립을 지양하고 소속기관의 추진계획을 종합, 자체 실정에 맞게 작성

정보시스템 관리대장

[illegible]

보안 서약서

본인은 년 월 일부로 관련 용역사업(업무)을 수행
함에 있어 다음 사항을 준수할 것을 엄숙히 서약합니다.

1. 본인은 관련 비밀로 분류될 성질의 업무를 수행함에 있어 소관 업무가 직무상 기밀 사항임을 인정한다.
2. 본인은 이 기밀을 누설함이 국가안전보장 및 국가이익에 위해가 될 수 있음을 인식하여 업무수행 중 지득한 제반 기밀사항을 누설하거나 공개하지 아니한다.
3. 본인이 이 기밀을 누설하거나 관계 규정을 위반한 때에는 관련 법령 및 계약에 따른 처벌 및 불이익을 받는다.
4. 본인은 하도급업체를 통한 사업 수행시 하도급업체로 인해 발생하는 위반사항에 대하여 책임을 부담한다.

※ 다만, 「부패방지 및 국민권익위원회의 설치와 운영에 관한 법률」 제66조제3항(제67조에서 준용하는 경우를 포함한다) 및 「공익신고자 보호법」 제14조제3항(「부정청탁 및 금품등 수수의 금지에 관한 법률」 제15조제4항에서 준용하는 경우를 포함한다)에 해당하는 경우에는 예외로 한다.

년 월 일

서 약 자 업 체 명 :
 직 위 :
 성 명 : (서명)

[illegible]

비밀 유지 서약서

계 약 번 호		계 약 기 간	
사 업 명			
주 관 기 관			

당사는 ○○○업무 용역사업을 수행함에 있어서 계약한 사항 이외에 「국가정보보안 기본지침」, 「국민권익위원회 보안업무규정 시행세칙」, 「국민권익위원회 정보보호 규정」 및 「정보화용역사업 보안관리 매뉴얼」에서 요구하는 보안규정을 성실히 이행할 것입니다. 만일 이를 위반할 경우 사업자 보안위규 처리기준 및 보안 위약금 부과 기준에 근거하여 행정 조치하고, 또한 손해가 발생할 경우 그에 대한 민·형사상의 모든 책임을 부담할 것을 확약합니다.

※ 다만, 「부패방지 및 국민권익위원회의 설치와 운영에 관한 법률」 제66조제3항(제67조에서 준용하는 경우를 포함한다) 및 「공익신고자 보호법」 제14조제3항(「부정청탁 및 금품등 수수의 금지에 관한 법률」 제15조제4항에서 준용하는 경우를 포함한다)에 해당하는 경우에는 예외로 한다.

년 월 일

서 약 자 주 소 :
(업체대표) 상 호 :
성 명 : (인)

서약집행자 소 속 :
(담당과장) 직 위 :
성 명 : (인)

국민권익위원회 위원장 귀하

[별지 제4호 서식]

정보보호시스템 도입시 확인사항

항목명	점검 항목	결과
인 증	EAL 2 이상 CC인증 획득 여부	
	CC인증을 받지 않은 경우, 국가용 암호제품 지정 여부	
	국가정보원장이 검증한 암호모듈 탑재 여부	
일치성	인증보고서 또는 운용정책문서와 도입제품 보안기능 일치성 여부	
	기술제안요청서(RFP)에서 요구하는 보안기능 구현 여부	
운용환경	도입기관의 시스템 관리자 지정여부	
	감사기능 지원 여부	
	네트워크 성능 요구사항 만족 여부	
	시스템 장애시 대책 수립 여부	
유지보수	보안적합성 검증결과 반영 기능 여부	
	업체 기술지원 전담조직 운영 여부	
	작동중단 등 긴급 상황에 대비한 지원 절차 마련 여부	
	업체 유지보수 매뉴얼 제공 여부	
	관리자 설치·운영 매뉴얼 제공 여부	
	업체의 제품 운용교육 제공 여부	
	신규취약점에 대한 통보 및 처리절차 마련 여부	

※ 점검결과는 O, X로 표기

[별지 제7호 서식]

사용자 계정 관리대장

연 번	소 속	성 명	업무명	계 정	접근권한	처리내용 (등록, 수정, 삭제)	처리 일자	확인

[별지 제8호 서식]

정보자산 보안등급표

관리책임자		자산번호
정	부	
		보호등급

[별지 제9호 서식]

무선랜 점검기록부

담당자	과장

점검일시	점검부서	사용 유무	무선랜 장비				구입일자	점검부서		확인부서		비고
			장비명	제조사	적용기술 (무선랜 규격)	고정IP유무		성명	서명	성명	서명	

[별지 제10호 서식]

무선랜 점검항목 확인대장

과/팀 명 :
 담 당 자 : (인)

보안조치	점검 내용	체크리스트			비고
		중요도	확인자	서명	
관리적 조치	무선랜 사용이 반드시 필요한가?	중요			
	무선랜 장비에 적용된 기술은? (IEEE 802.1x, WEP/TKIP/CCMP 등)	중요			
	무선랜 장비와 관련된 매뉴얼은 구비하고 있는가?	선택			
	무선랜 설치공간에 대한 물리적 보호장치를 마련하여 도난 및 비인가 조작으로부터 보호할 대책은 마련하였는가?	중요			
	무선 구간을 통해 통신되는 정보의 종류를 파악하였는가?	중요			
	무선 서비스 제공 범위를 파악하고 있는가?	중요			
	AP 및 무선랜카드 목록을 작성하는 등 운영되는 무선랜 장비를 파악하고 있는가?	중요			
운영적 조치	무선랜 사용시 해킹 등 정보보안 취약점에 대해 사용자에게 교육을 실시하고 있는가?	중요			
	무선랜 장비에 대한 소프트웨어 패치 및 업그레이드 상황을 정기적으로 확인하여 적용하는가?	중요			
	무선랜 전용 침입탐지시스템을 설치, 운영하는가?	선택			
기술적 조치	AP에서 로그 기능을 지원하는 경우, 주기적으로 로그 감사를 실시하는가?	중요			
	관리자 암호변경 등 AP 사용시 초기 설정 값과 기능을 사용 환경에 맞도록 재설정하여 사용하는가?	중요			
	128bit 이상의 암호키 값 설정 등 AP 사용시 보안기능을 적용하여 사용하는가?	중요			
	무선랜 단말기 시스템에 바이러스 백신 등 정보보호보안 제품을 설치하여 사용하는가?	중요			
	무선랜 이용자가 파일 공유 기능을 사용하지 못하도록 하는가?	중요			
	무선랜 사용시 DHCP 사용을 금지하고 고정 IP를 사용하도록 하는가?	선택			
	AP 관리를 위한 트래픽은 반드시 유선랜을 사용하도록 설정하는가?	중요			

[별지 제11호 서식]

무선랜 장비 관리대장

과/팀 명 :
 담 당 자 : (인)

연 번	관리번호	장비명	제조사	구입일자	등록일자	비고
1						
2						
3						
4						
5						
6						
7						
8						
9						
10						
11						
12						
13						
14						
15						

정보시스템 보안취약점 점검표

서비스명		서버명			
작업일시		모델명			
작업내역					
순번	OS 보안 점검항목	O	X	비고	
1	OS에 대한 최신 패치를 적용 하였는가?				
2	OS 취약점 점검을 실시하였는가?				
3	서버 전용 호스트로 구성하였는가?				
4	서버에 대한 접근 제어설정을 하였는가?				
5	관리자 계정은 9자 이상(특수문자 1자 이상사용)P/W를 사용하는가?				
6	관리자 계정의 패스워드를 주기적으로 변경하는가?				
7	파일 접근권한을 설정하였는가?				
8	불필요한 서비스 포트를 제거 하였는가?				
순번	응용서버 설치보안 점검항목				
1	소스코드 형태의 배포본으로 설치하였는가?				
2	설치 시 네트워크 접속 차단을 하였는가?				
3	응용 프로세스의 권한 제한을 설정하였는가?				
4	로그 파일 보호설정을 하였는가?				
5	응용 서비스 영역을 분리하였는가?				
6	서버의 다른 디렉토리로의 심볼릭 링크를 제거하였는가?				
7	디렉토리 리스팅 기능을 사용중지 하였는가?(홈페이지 서버의 경우)				
8	기본 문서(index파일) 설정을 하였는가?(홈페이지 서버의 경우)				
9	샘플 파일, 매뉴얼 파일, 임시 파일을 제거하였는가?				
10	응용 서버에 대한 불필요한 정보 노출을 방지하였는가?				
11	불필요한 파일의 업로드를 제한하였는가?				
12	응용 서버에서 인증과 접근제어 기능을 사용하였는가?				
13	패스워드 설정 정책은 수립하여 운영하였는가?				
14	응용 서버 설치 후 패치를 수행하였는가?				
15	설정파일을 백업하였는가?				
16	SSL/TLS를 사용하였는가?				
순번	네트워크 취약점 점검항목				
1	네트워크 장비의 원격 접근 제한 설정을 하였는가?				
2	SNMP 기능을 사용하였는가?				
3	네트워크 장비의 디폴트 아이디/패스워드 사용금지 하였는가?				
3-1	-Community 문자열을 재설정 하였는가?				
3-2	-SNMP 암호화 기능을 사용하였는가?				
4	네트워크 장비의 디폴트 아이디/패스워드를 변경하였는가?				
5	네트워크 장비의 불필요한 서비스를 중단하였는가?				
6	설정을 통해 장비의 로그인 시간을 제한하였는가?				
7	네트워크 장비의 로그를 관리하고 있는가?				

서비		서			
작업일시		모			
작업내역					
순번	DB취약 점검항목(My-SQL)			O	X 비고
1	최신 패치를 적용하였는가?				
2	Default 관리자 아이디를 변경하였는가?				
3	모든 DBMS 계정에 대해 패스워드를 설정하였는가?				
4	원격에서 My-SQL 서버로의 접속을 적절히 제한하였는가?				
5	My-SQL 계정에 대한 접속차단을 설정하였는가?				
6	시스템 사용자들의 DB에 대한 권한설정을 하였는가?				
7	데이터 베이스내의 사용자별로 접속/권한 설정을 하였는가?				
8	My-SQL의 데이터 디렉토리 보호설정을 하였는가?				
순번	DB취약 점검항목(MS-SQL)				
1	OS 취약점 점검을 실시하였는가?				
2	guest 계정을 삭제하였는가?				
3	public DB의 부여권한을 해제하였는가?				
4	SYSADMIN그룹의 사용자 제한을 설정하였는가?				
5	DB서버로의 원격접속을 적절히 제한하였는가?				
6	최신 서비스 팩을 설치하였는가?				
7	DB서버로의 연결 보안감사를 설정하였는가?				
순번	DB취약 점검항목(Oracle)				
1	디폴트 아이디의 사용제한 또는 패스워드를 변경하였는가?				
2	Data Dictionary 보호를 위해 파라미터 내용을 수정하였는가?				
3	사용자에게 최소한의 권한만을 부여하였는가?				
4	클라이언트 인증을 통한 원격인증을 제한하였는가?				
5	DB 시스템의 사용자 수를 제한하였는가?				
6	원격에서의 오라클 리스너 설정변경을 제한하였는가?				
7	원격접속을 허용할 IP대역을 설정하였는가?				
8	DB 서버에서 불필요한 서비스를 제거하였는가?				
9	Oracle의 최신 보안패치를 설치하였는가?				
10	DB 서버의 최신 보안패치를 설치하였는가?				
순번	웹 어플리케이션 보안점검 항목				
1	SQL Injection취약점에 대해 점검하였는가?				
2	Cross Site Script(XSS)취약점에 대해 점검하였는가?				
3	악성화일 실행 파일 업로드 취약점에 대해 점검하였는가?				
4	악성화일 실행 파일 다운로드 취약점에 대해 점검하였는가?				
5	쿠키변조 취약점에 대해 점검 하였는가?				
순번	웹 패키지 S/W 관리				
1	사용중인 웹 패키지의 S/W를 파악하고 있는가?				
2	주기적인 취약점 및 패치를 실시하고 있는가?				
점검자		소 속 : 성 명 :		확인자 소 속 : 성 명 :	

※ 해당없는 항목은 '비고'란에 '해당 없음'으로 표기

[별지 제13호 서식]

자료 반출.입 보안조치 관리대장

순번	자료명	제공사유	제공기간	매체	제 공			회 수		
					제공일	인계자	인수자	회수일	인계자	인수자

[별지 제14호 서식]

시스템 계정 신청서

소속 :
직책 :
계정 사용 개시 희망일 :

대상시스템	☐ 서버 ☐ 데이터베이스		
신청 구분	☐ 신규 ☐ 변경 ☐ 삭제	신청사유	
사용 기간	(일시 사용자만 기재요)		
접근권한			
서버	1.사용자 그룹: 2.사용자 권한 ☐ Administrator권한 ☐ 시스템S/W 관리자 권한 (해당 시스템S/W 명 :) ☐ 일반 사용자 권한 3.기타 필요한 권한: ()		
데이터베이스	1.사용자 그룹: 2.사용자 권한 ☐ DBA권한 ☐ 일반 사용자 권한 3. 기타 필요한 권한: ()		

신청자 성명 : (인)
< 계정 승인자 인적사항 >
소속 :
직책 :
성명 : (서명)

[별지 제15호 서식]

네트워크 보안정책 설정 신청서

□ 신청자 정보

부서명				전화	
				팩스	
부서장명		직책		연락처	
담당자명		직책		연락처	

□ 서비스 신청 내용

출발지(Source IP) 객체 정보			
IP Address		시스템명(hostname)	
시스템 용도		시스템 위치	

목적지(Destination IP) 객체 정보			
IP Address		시스템명(hostname)	
시스템 용도		시스템 위치	

IP Protocol	포트번호	차단/허용	통신방향	포트 용도	사 용 기 간			
TCP □		차단 □	단방향 □		영구 □	년	월	일부터
UDP □		허용 □	양방향 □			년	월	일까지
TCP □		차단 □	단방향 □		영구 □	년	월	일부터
UDP □		허용 □	양방향 □			년	월	일까지
TCP □		차단 □	단방향 □		영구 □	년	월	일부터
UDP □		허용 □	양방향 □			년	월	일까지

서비스요청 목적 (명확히 기술)	
----------------------	--

상기 요청한 보안정책은 시스템 관리/서비스를 위해 필요한 정책으로,
반드시 요청한 목적으로만 사용하도록 하겠습니다.

20

신 청 자 (인)

[별지 제16호 서식]

정보보안 사고 신고서

기본정보			
기관명		부서	
성명		직위	
전자우편			
연락처			
사고내용			
사고일시		피해IP주소	
피해시스템 용도		운영체제	
사고유형		피해범위	
사고내용			
조치내용			
공격자 정보			
피해현황			
긴급조치 실시사항			
관련보안 제품 운영현황			
그 밖에 사고관련 내용을 구체적으로 서술			

저장매체 자료 삭제 확인서

[illegible]

구분	소속	성명	확인
정보시스템 담당자			
정보보안담당관			

보안확약서

1. 본인은 업체 및 사업 참여자가 사업수행 중 알게 된 모든 자료를 반납 및 파기하였으며, 알게 된 정보에 대한 유출을 금지하겠습니다.
2. 본인은 하도급업체에 대해 상기 항과 동일한 보안사항 준수 책임을 확인하고 보안확약서를 징구하였으며, 하도급업체가 위의 보안사항을 위반할 경우에 주사업자로서 이에 따른 법적 책임을 지겠습니다.
3. 본인은 상기 보안사항을 위반할 경우에 귀 기관의 사업에 참여 제한 또는 기타 관련 법규에 따른 책임과 손해배상을 감수하겠습니다.

의
의
의

화 약 자 업 체 명 :
 (업 체 대 표) 직 위 :
 성 명 : (서명)

국민권익위원회 위원장 귀하

[별지 제19호 서식]

백업 관리대장

순번	백업일자	시작시각	종료시각	백업방식	백업매체	백업대상	보관장소	보관 기간	담당자	열람일시	열람자	비고

[별지 제20호 서식]

정보시스템 서비스 포트 관리대장

담당자 :

업무명	시스템명	서버명	서버IP	포트 번호	비고
인터넷	인터넷	DB서버	0.0.0.0	1521	예시

[별지 제21호 서식]

PC · 노트북 관리대장

연번	모델명	제조사	규격				도입 년월	도입 가격 (원)	관리 번호	취급 부서	취급자	상태
			운영 체제	CPU	RAM	HDD						
1	(작성예)											
2	삼보 Dreamsys	삼보	Windows XP HOME	펜티엄4 3.4Ghz	10G	1T	2012-01-01	1,000,000	라벨 번호	혁신행정	홍길동	사용
3												
4												
5												
6												
7												
8												
9												
10												

[별지 제22호 서식]

정보통신실 상시 출입자 명단

결 재	담당	확인	과장

번호	소속	직급	성명	비고
1				
2				
3				
4				
5				
6				
7				
8				
9				
10				
11				
12				
13				
14				
15				

정보통신실 출입자 관리대장

기간 :

No.	출입일자	소속	성 명 (인)	입실시간	퇴실시간	출입목적	연락처	입회자 성명

※ 경고 : 출입시 제반 보안사항을 준수하여야 합니다.

* 노트북, 기억매체, 카메라, 카메라폰, 캠코더 등 영상저장용 장비 등은 반입 금지

정보보호시스템 보안기능 점검표

대분류	보안기능 요구사항	점검결과	비고
감사기록	감사의 시작/종료, 관리자 또는 사용자에 대한 식별 및 인증성공/실패, 제품 설정 변경내역, 보안기능 수행 내역 등 감사데이터 생성 * 네트워크 차단 기능이 있는 경우 허용 및 차단된 모든 트래픽에 대한 감사 데이터 생성		
	감사 데이터는 사건 발생일시, 사건유형, 사건을 발생 시킨 주체의 신원(가능 경우), 작업내역 및 결과(성공/실패)를 상세히 포함		
	인가된 관리자가 제품구성요소로부터 생성된 모든 감사데이터를 검사할 수 있는 기능 제공		
	인가된 관리자 또는 인가된 사용자가 AND, OR 등 논리적 관계기준에 기초하여 감사레코드를 선택적으로 검토		
	감사 증적내 저장된 감사레코드에 대해 비인가된 삭제 또는 변경이 발생하지 않도록 보호 - 인가된 관리자라 할지라도 삭제 또는 변경할 수 없도록 삭제·변경 관련 유저인터페이스가 제공되지 않아야 됨 - 감사레코드에 대한 보호대책을 제품의 보안기능으로 완전히 구현할 수 없는 경우, 운용환경의 지원을 받을 수 있음		
	감사 증적의 크기가 지정된 한도를 초과할 경우, 사전 정의한 방식에 따라 관리자에게 통보		
	감사 증적의 포화시 적절한 방법(예:오래된 감사레코드 덮어쓰기 등)으로 저장 실패에 대응		
	주요 사건에 대한 정확한 시각 정보생성을 위해 신뢰된 OS등을 이용하여 시간 정보를 생성		
	잠재적인 보안위반을 탐지한 경우, 인가된 관리자가 설정한 대응(예:정보메세지 발송 등)을 수행		

대분류	보안기능 요구사항	점검결과	비고
식별 및 인증	관리자 또는 사용자 신원을 검증하기 위해 식별 및 인증기능 제공		
	관리자 인증실패가 설정된 횟수(기본값 5회이하)에 도달하면, 인가된 관리자가 설정한 시간(기본값 5분 이상)동안 식별 및 인증기능이 비활성화		
	패스워드 등록시 보안성기준(영문대문자/영문소문자/숫자/특수문자 중 3가지 이상의 규칙조합 및 9자리 이상으로 구성)을 만족하는지 검증		
	인증이 진행되는 동안 관리자 또는 사용자에게 패스워드가 마스킹(예:****등)되어 보이도록 해야 됨		
	식별 및 인증 실패시 실패이유에 대한 피드백(예:ID 오류, 패스워드 오류 등)을 제공하지 않아야 됨		
	관리자가 제품에 최초 접속시 제품이 기본적(예:설치 시 등)으로 제공하는 ID 및 패스워드의 변경을 강제화하는 기능 제공		
	관리자의 패스워드가 제품에 하드코딩되거나 평문(단순인코딩 포함)으로 저장되지 않아야 함		
	인증정보가 재사용되는 것을 방지(타임스탬프 사용 등)해야 됨		
보안관리	인가된 관리자가 보안기능, 보안정책 및 중요데이터 등을 설정 및 고나리할 수 있는 보안기능 제공		
	사전 등록된 IP주소의 관리콘솔(관리자 IP주소 등록은 2개 이하로 제한)만 제품에 접속할 수 있도록 해야 함		
전송 데이터 보호	물리적으로 분리된 제품 구성요소간 전송데이터(보안정책, 제어명령, 감사기록 등)에 대한 암호화를 통해 기밀성 및 무결성 보장		
	- 에이전트와 관리서버간 전송되는 데이터에 대한 기밀성 및 무결성 보장을 위해 상호 인증을 수행		
	- 암호보통 검증제도에서 검증대상으로 지정된 안전한 암호 알고리즘 사용을 권고		
	- 관제대상 시스템으로부터 로그를 Syslog형태로 수신하는 경우 본 요구사항은 적용되지 않음, 단 전송 과정에서 로그정보가 훼손될 수 있으므로 동일 로컬 네트워크 내에서만 Syslog사용 등 보호대책을 마련해야 됨		
	관리자의 웹브라우저를 이용한 접속 등 제품과 원격으로 연결된 모든 통신 수단은 안전한 암호통신 프로토콜을 사용		

대분류	보안기능 요구사항	점검결과	비고
자체시험	제품의 정확한 운영을 보장하기 위해 시동시와 정규 운영동안 주기적으로 자체 시험을 실행		
	인가된 관리자에게 제품의 설정값 및 제품 자체의 무결성을 검증하는 기능 제공		
안전한 세션 관리	로그인 이후 일정시간(기본값 10분이하)동안 동작이 없을 경우 세션 잠금 또는 세션 종료 기능을 수행		
	로그인 이후 다른 단말에서 동일 계정 또는 동일 권한으로 로그인을 다시 수행하는 경우, 신규 접속을 차단하거나 이전 접속을 종료 *제품 운영상화 등에 대한 모니터링만 수행하는 관리자 계정에 대해서는 중복 로그인 허용 가능		
정보 흐름 통제	인가된 관리자에 의해 설정된 규칙에 따라 인입 및 트래픽을 차단 - 정보흐름통제 규칙은 개별 또는 특정 대역의 출발지/목적지 주소 및 포트 등 다양한 정보에 의해 구성 - 3,000개 이상의 차단 규칙 생성·관리(ips에 한함) - 기본적으로 모든 트래픽을 차단한 뒤, 규칙에 따라 특정서비스/포트 출발지/목적지 주소기반은 화이트리스트 방식이, 시그니처 또는 유해사이트 목적기반은 블랙리스트 방식 적용을 권고하나 장애시 모든 트래픽을 통과시킬 수 있는 기능은 제공되지 않아야 함		
	제품 설정 등을 통해 다음의 정보흐름 차단 가능 - 외부로부터 들어오는 트래픽 중 내부 IP주소가 출발지인 트래픽 - 내부에서 나가는 트래픽 중 외부 IP주소가 출발지인 트래픽 - 외부로부터 들어오는 트래픽 중 브로드캐스트 주소가 목적지인 트래픽 - 외부로부터 들어오는 트래픽 중 루프백 주소가 목적지인 트래픽 - 외부로부터 들어오는 트래픽 중 비정상적인 패킷 형식을 가지는 트래픽		

[별지 제25호 서식]

정보보안시스템 운영 점검사항

항목명	운영 점검사항	점검결과	비고
보안정책 설정	도입기관의 보안정책에 근거하여 제품의 보안기능 정책을 설정		
우회방지	SSH 터널링을 통한 제품의 차단기능 우회를 방지		
인증서 운영	제품의 관리콘솔에 설정된 서버 인증서는 기관에 설치시 발급된 유일한 인증서이어야 하며 인증서 공개키는 RSA 2048비트 이상 또는 그와 동등한 안전성을 보장하는 키길이 이어야 한다. 인증서 서명 알고리즘 및 해쉬 알고리즘은 암호모듈 검증제도에서 명시된 검증대상 암호 알고리즘이어야 한다. - 발급자 : 도입기관에서 지정한 신뢰기관 확인 - 유효기간 : 유효기간 만료 여부 확인 - 주체 : 인증서 발급 대상자 확인 - 공개키 : 제품별로 상이한 공개키가 사용되는지 다른 제품 인증서의 공개키 값과 비교 - 공개키 길이 : RSA 2048비트 이상 - 해쉬함수 : SHA224, SHA256 등(224비트 이상 출력 알고리즘)		
최신버전 소프트웨어 설치	도입제품에서 사용되는 SNMP, OpenSSL, OpenSSH, DBMS 모듈이 최신버전이 아닌 경우 취약점을 가지고 있을 수 있으므로 해당 버전을 확인 - SNMP V3 사용 - 최신 버전의 OpenSSL, OpenSSH 버전 사용		
불필요한 서비스 제거	제품에 불필요한 서비스가 동작하지 않아야 함		
안전한 업데이트 적용	업데이트 대상 및 방식을 참조하여 업데이트 정책을 수립 [업데이트 대상] - 공격패턴 파일, 차단 엔진, 기타 실행파일/설정파일 등 제품 주요 업데이트 파일		

항목명	운영 점검사항	점검결과	비고
	[업데이트 방식] - 온라인 업데이트 : 제품 개발업체 업데이트 서버를 통한 온라인 업데이트 방식의 경우 업데이트 서버에 대한 인증과 업데이트 데이터에 대한 기밀성 및 무결성 검증 기능이 제공되어야 함 - 오프라인 업데이트 : 제품 개발업체로부터 오프라인 방식으로 업데이트를 제공받고 업데이트 적용시 데이터에 대한 무결성 검증 기능이 제공되어야 함 [업데이트 관리] - 제품이 제공하는 업데이트 방식을 확인하여 업데이트 정책을 수립하고 적절한 업데이트가 이루어 질 수 있도록 해야 함 - 업데이트 시 제품의 주요 엔진을 변경하는 경우 도입된 CC인증제품에 대한 형상변경을 가져올 수도 있음. 업데이트 정책 수립시 업체와 업데이트되는 내용을 협의하여 도입제품에 대해 무단 형상변경이 발생하지 않도록 유의해야 함		
백업	관리자는 감사기록 유실에 대비하여 감사데이터 저장소의 여유 공간을 주기적으로 확인하고 감사기록이 소진되지 않도록 감사기록 백업 등을 수행		
관리자 운영	관리서버는 인가된 관리자만이 접근 가능한 물리적으로 안전한 환경에 설치·운영되어야하며 외부 원격관리를 허용하지 않아야 함 원격관리는 원칙적으로 금지하나 불가피한 경우 내부망의 지정된 단말기에서만 접속하도록 통제하여야 함		
	관리콘솔에 접근 가능한 IP주소는 화이트리스트 방식으로 설정		

※ 별표 3의 CC인증 의무화 도입 제품군은 해당 제품군 양식을 활용

[별지 제26호 서식]

네트워크 장비 보안적합성 검증 신청서

신청기관	기관명			운영부서		
				기관담당자		
				담당자 연락처		
	도입목적					
신청제품	사업명					
	업체명			대표자		
	주소			전화번호		
	제품명	*신청제품이 2종 이상일 경우, 추가기재		CC인증번호		
				암호검증 번호		
		제품종류			펌웨어 파일명	
	도입수량			해시값		
	평가기관		인증 기관		등급	
	업체실무 담당자	전화번호				
		휴대전화번호				
E-mail						
암호모듈	☐ 없음 ☐ 없음(☐ 검증 ☐ 미 검증)					

[별지 제27호 서식]

네트워크 장비 도입 최소 보안 요구사항

대분류	소항목	내용	점검결과
식별 및 인증	디폴트 관리자 패스워드 강제 변경 기능	- 제품 출고시 디폴트 관리자 패스워드 설정 금지 - 디폴트 관리자 패스워드 설정된 경우	
	안전한 패스워드 설정 기능	최소9자리이상, 영문 대/소문자, 숫자, 특수문자 중 3가지 이상 규칙조합사용	
	인증실패 대응 기능	설정된 횟수(기본값 5회이하) 이상 인증 실패시 일정시간(기본값 5분이상) 접속제한 등의 대응 기능 제공	
	인증 피드백 보호 기능	입력한 패스워드 정보를 화면에서 볼 수 없도록 마스킹하는 기능	
	관리자/사용자 인증 정보의 안전한 저장 여부	- 평문(Base64와 같은 단순 인코딩 포함) 저장 금지 - 제품에 하드 코딩 금지	
	별도 서버를 통한 사용자 인증기능 *별도 인증서버 연동을 제공 하는 경우	- IEEE 802, 1x지원 - RADIUS, TACACS + 서버 등 지원	
정보흐름 통제	관리자가 설정한 ACL규칙에 따라 트래픽을 제어하는 기능 제공여부	- ACL규칙(MAC, IP, 포트 등)을 통한 트래픽 제어 지원 - IEEE802, 1Q VLAN, VLAN Trunking 지원	
보안관리	SNMP를 이용한 시스템 모니터링 및 관리기능 제공 여부	- 초기 설정은 SNMP서비스 비활성(Disable) 상태 유지 - 최신 SNMP버전(V3) 지원 - Private MIB정보 문서화 제공	
	관리콘솔 접속가능 IP제한 기능	IP지정(2개 이하로 제한)	
자체시험	제품구동시, 정규 운영동안 주기적으로 관리자 요치시 자체 시험을 실행하는 기능 제공여부	- 제품관련 H/W(메모리, 플래시 등)의 자체 검사지원 - 제품관련 S/W(커널, 운영프로그램 등)의 자체 검사 지원	
	관리자에게 제품 설정값 및 실행코드의 무결성을 검사하는 기능	-	

대분류	소항목	내용	점검결과
	펌웨어 업데이트시 펌웨어 파일의 안전한 무결성 검증방법 여부	· 전자서명 생성/검증 메커니즘 이용 등 검증기능 여부	
안 전 한 세션관리	일정시간 관리자 활동이 없는 경우 세션 잠금 또는 세션 종료기능	· 기본값 10분 이하	
	관리자의 동시 원격 접속 세션을 제한하는 기능	· 하나의 관리자 세션 유지 * 제품 운영상황 등 단순 모니터링만 수행하는 경우에는 예외적으로 허용	
	관리자 인증정보 재사용 방지대응 기능 *웹UI를 제공하는 경우	· 타임스탬프 등 대응기능 제공	
접근통제	다중 사용자/그룹 생성지원 및 사용자/그룹별 접근 권한 설정 기능	· 사용자별 이름(ID), 패스워드, 접근권한 설정 지원	
	제품 모니터링, 설정 변경/삭제, 엔지니어 진단, 복구 모드 등 운영모드의 안전한 제공	· 제품이 지원하는 운영모드 명시 · 각 모드 변경시 명시적 인증 확인 · 운영모드별 필요한 최소한의 명령만 사용 허용	
전송데이터 보호	제품과 원격 연결된 모든 통신수단간 안전한 암호통신 프로토콜 사용	· 관리자 PC에서 원격으로 관리콘솔 접속시 SSL/TLS, HTTPS, SSH, IPSEC 등 사용 지원 · 제품과 외부 서버와의 원격으로 연동시 SSL/TLS, HTTPS, SSH, IPSEC 등 사용 지원	
감사기록	감사 데이터를 생성하는 기능	· 감사의 기능의 시작/종료 · 관리자에 대한 식별 및 인증 성공/실패 · 제품설명 변경내역, 보안기능 수행내역	
	감사데이터의 해당 정보 포함 여부	· 사건 발생일시, 사건 유형 · 사건을 발생시킨 주체의 신원(가능한 경우) · 작업내역 및 결과(성공/실패)	
	감사증적의 크기가 디스크 용량 초과시 대응 행동	· 오래된 감사 레코드 덮어쓰기 등 대응 내용	

[별지 제28호 서식]

네트워크 변경내용 분석서

1. 제품 개요

가. 작성자 정보 : 업체명, 작성일, 작성자 등

도 입 기 관	
개 발 업 체	
작 성 일	
작 성 자	

나. 검증제품 : 제품명, 버전, 펌웨어 해시값 등

제 품 명	
버 전	
펌 웨 어 파 일 명(해시값)	
검 증 일	

다. 이전 ‘변경승인’에 관련된 내용

제품명	버전	변경승인일	변경승인내용

2. 변경 내역

가. 변경 전/후 시스템 구성

제품명	소프트웨어		하드웨어	
	변경 전	변경 후	변경 전	변경 후

나. 검증제품 : 제품명, 버전, 펌웨어 해시값 등

변경된 기능	변경내용
로그인	관리자 로그인시 비밀통신을 수행하도록 제품 변경 *필요시 화면 캡처

다. 변경이 제품 설계에 미치는 영향

항 목	영 향 분 석
펌웨어 변경유무	로그인 기능 변경을 위해 관리자 인증과 관련된 일부코드가 변경됨에 따라 펌웨어가 변경됨 *필요시 화면 캡처
	로그인 기능 변경을 위해 내부 코드가 변경되었으며 제품UI 변경은 없음 *필요시 화면 캡처

라. 변경부분에 대한 자체시험 테스트 결과

변경된 기능	시험내용	시험 결과
로그인	관리자 로그인시 비밀번호 실패 횟수 확인	정상동작 확인 *필요시 화면 캡처
*****	*****	*****

[별지 제29호 서식]

정보보호시스템 도입 확인서

기 관 명		기관 명	
담 당 자		담당자 전화번호	
사 업 명			
보안성검토			

[illegible]

[부록 1]

부 록

USB 메모리 등 휴대용 저장매체
보안관리지침

제1조(목적) 이 지침은 「국민권익위원회 정보보호규정」 제56조에 따라 USB(Universal Serial Bus)메모리 등 휴대용 저장매체 보안 관리에 필요한 세부사항을 규정함을 목적으로 한다.

제2조(정의) 이 지침에서 사용하는 용어의 정의는 다음과 같다.

- ① “휴대용 저장매체”라 함은 디스켓, 외장형 하드디스크(HDD), USB메모리, CD(Compact Disk) DVD(Digital Versatile Disk) 등 자료를 저장할 수 있는 일체의 것으로 PC 등의 정보통신 시스템과 분리할 수 있는 기억장치를 말한다.
- ② “휴대용 저장매체 관리책임자”(이하 “관리책임자”라 한다)라 함은 각 부서별 휴대용 저장매체 관리상의 책임을 맡은 부서의 장을 말한다.
- ③ “휴대용 저장매체 취급자”(이하 “취급자”라 한다)라 함은 해당 휴대용 저장매체를 사용하는 자를 말한다.
- ④ “휴대용 저장매체 관리시스템”(이하 “관리시스템”이라 한다)이라 함은 휴대용 저장매체의 등록, 파기, 재사용, 반출입, 불용처리 현황 등에 관하여 전자적으로 처리하는 시스템을 말한다.
- ⑤ “휴대용 저장매체 관리번호”(이하 “관리번호”라 한다)라 함은 사용 중인 휴대용 저장매체의 식별 및 관리를 용이하도록 부여한 번호를 말한다.

제4조(USB메모리 및 관리시스템 도입) ① 정보보안담당관은 USB메모리 및 관리시스템을 도입할 경우 그 제품의 안정성을 검증하기 위하여 국가정보원장에게 보안적합성을 검증을 의뢰하여야 한다.

② 도입할 USB메모리 및 관리시스템은 다음 각 호에 해당하는 필수 보안기능을 포함하여야 한다.

1. 사용자 식별·인증기능
2. 지정데이터 암호화 기능
3. 저장된 자료의 임의 복제 방지기능
4. 분실 시 저장데이터의 보호를 위한 삭제 기능

③ 정보보안담당관은 운용중인 휴대용 저장매체를 안전하게 관리하기 위하여 관리시스템을 구축할 수 있다. 이 경우 별지 제1호부터 별지 제5호까지의 서식에 같음할 수 있다.

제5조(휴대용 저장매체 사용) 위원회에서 사용하는 모든 휴대용 저장매체는 제7조의 규정에 따라 각 부서별 <별지 제1호 서식>을 이용하여 휴대용 저장매체 관리대장(이하

“관리대장”이라 한다)에 등록 후 사용하여야 한다.

제6조(휴대용 저장매체 사용제한) ① 사용자는 등록된 휴대용 저장매체만 사용할 수 있으며 업무목적 이외 사적인 용도로 사용할 수 없다.

② 정보보안담당관은 소속직원에게 공자교육을 통하여 휴대용 저장매체의 임의 사용을 제한하여야 하고 이에 대하여 주기적인 점검을 실시하여야 한다.

제7조(관리책임자) ① 휴대용 저장매체는 각 부서장 책임 하에 관리하는 것을 원칙으로 하며 부서장을 “관리책임자”라 칭한다.

② 관리책임자는 소관 부서에서 휴대용 저장매체를 사용할 경우, <별지 제1호 서식>의 관리대장을 각각 비치하여야 한다.

③ 관리책임자는 월 1회 이상 휴대용 저장매체 수량 및 보관 상태를 점검하고 <별지 제2호 서식>에 따라 확인·서명하여야 한다.

④ 관리책임자는 휴대용 저장매체의 반출입을 통제하여야 하며 <별지 제3호 서식>에 따라 기록하여야 한다. 이때 반출입은 업무상 목적(<별지 제3호 서식>의 “용도” 참조)에 한한다.

⑤ 관리책임자는 소속직원이 휴대용 저장매체를 무단 반출하거나 미등록 휴대용 저장매체를 사용하지 않도록 감독하여야 하며 이를 위반한 사실을 인지·확인하는 즉시 정보보안담당관에게 통지하여야 한다.

제8조(정보보안담당관의 책무) ① 정보보안담당관은 소속기관 내에서 사용하는 휴대용 저장매체 등록현황을 파악하여야 한다. 이 경우 각 부서별 관리대장 사본을 비치·관리하는 것으로 같음할 수 있다.

② 정보보안담당관은 각 부서별 관리책임자가 <별지 제4호 서식>에 따라 휴대용 저장매체 라벨 작성 및 <별지 제5호 서식>에 따라 불용처리 확인을 요청하는 경우에는 확인한 후 날인하여야 한다.

③ 정보보안담당관은 휴대용 저장매체를 일괄 구입하여 필요한 부서에 통합 보급할 수 있다.

④ 정보보안담당관은 휴대용 저장매체가 무단 반출입되거나 미등록 휴대용 저장매체에 업무 자료를 보관하는 지 여부 등을 주기적으로 점검하여야 하며, 관련 위규사례를 인지한 경우에는 경위조사를 실시하여야 한다.

⑤ 정보보안담당관은 대외비 자료가 보관된 휴대용 저장매체를 무단 반출·분실하거나 미등록 휴대용 저장매체에 보관하고 있는 경우에는 경위조사를 실시하여야 한다.

제9조(휴대용 저장매체의 구분 및 관리요령) ① 휴대용 저장매체의 관리요령은 다음과 같다.

1. 휴대용 저장매체는 업무관련 일반자료(공인인증서 포함)만 보관하여야 하며 <별지 제1호 서식>의 관리대장에 기록하여야 한다.
2. 휴대용 저장매체는 개인서랍, 캐비닛 등에 안전하게 보관하여야 한다.
3. 휴대용 저장매체는 <별지 제4호 서식>과 같이 기입·표시하여야 한다.
4. 관리번호는 부서명, 연번으로 한다. 이 경우 부서명은 약칭을 사용할 수 있다.
(예 : 110콜센터-01, 110콜센터-02, 110콜센터-03 등)

제10조(휴대용 저장매체 불용처리 및 재사용) ① 업무상 목적으로 사용한 휴대용 저장매체는 불용처리 시 물리적 파기를 원칙으로 하며 그 사실을 관리대장에 기록하여야 한다.

- ② 휴대용 저장매체는 타부서 이전 또는 용도를 전환하여 사용하고자 할 경우에는 수록된 자료를 완전히 삭제·포맷 후 사용하여야 한다.
- ③ 휴대용 저장매체를 불용하거나 재사용하는 경우에는 <별지 제5호 서식>에 따라 정보보안담당관의 확인을 받아야 하며 확인서를 보관하여야 한다.

제11조(휴대용 저장매체의 분실, 소각 시 대처방안) ① 취급자는 휴대용 저장매체의 분실 또는 소각 등의 사유가 발생한 즉시 관리책임자에게 그 사실을 보고하여야 한다.

- ② 관리책임자는 휴대용 저장매체의 분실 또는 소각사실을 보고받은 즉시 정보보안담당관에게 통지하여야 한다.
- ③ 정보보안담당관은 휴대용 저장매체의 분실 또는 소각 사실을 통지받거나 인지한 경우에는 자체 조사를 실시하고 재발방지 대책을 강구하여야 한다.

제12조(휴대용 저장매체 고장·훼손, 오인 삭제·포맷 시 대처방안) ① 휴대용 저장매체의 고장, 자료의 훼손 또는 자료의 오인삭제, 포맷 시 제10조의 규정에 따라 불용처리를 원칙으로 한다. 다만, 자료의 복구가 필요한 경우 상용 소프트웨어 활용 및 전문 업체에 의뢰할 수 있다.

- ② 제1항에 따라 전문 업체에 의뢰하는 경우에는 정보보안담당관 임회, 보안서약서 징구 등 적절한 보안대책을 강구하여야 한다.

<별지 제1호 서식>

휴대용 저장매체 관리대장

연번	관리번호	매체 형태	등록일자	취급자	불용처리일자	불용처리방법 (재사용용도)	비고
1	110콜센터-01	USB	'13.01.01	홍길동	'14.05.11	물리적 파괴	고장
2	110콜센터-02	외장형 HDD	'13.01.01	김유신	'14.05.24	포맷 후 재사용 (전산실-04)	
3							
4							
5							
6							
7							
8							
9							
10							
11							
12							
13							
14							
15							
16							
17							
18							
19							
20							

〈별지 제2호 서식〉

휴대용 저장매체 점검대장

[illegible]

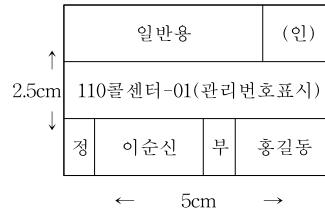
〈별지 제3호 서식〉

휴대용 저장매체(전산장비 포함) 반출·입 대장

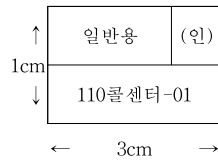
[illegible]

<별지 제4호 서식>

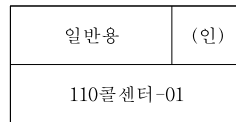
휴대용 저장매체 라벨



<디스켓, 이동형 HDD 서식>



<USB·CD 등 서식>



<예시 : USB·CD 등 서식>

- 가. 同 서식을 만들어 보조기억매체 중앙의 적절한 위치에 부착
 나. 첫 번째 줄에는 일반용은 정보보안담당관 또는 관리책임자의 직인을 날인
 다. 두 번째 줄에는 휴대용 저장매체 관리번호 표기
 라. 세 번째 줄의 ‘정’란에 관리책임자·‘부’란에 취급자 표기
 (USB메모리 및 CD의 경우 생략 가능)
 마. 휴대용 저장매체의 크기를 고려하여 서식·글자 크기 조정 가능

<별지 제5호 서식>

휴대용 저장매체 불용처리 확인서

아래와 같이 휴대용 저장매체(종 점) 불용처리 및 휴대용 저장매체(종 점) 재사용에 대해 확인을 요청함

연번	관리번호	매체형태	사유	불용처리	재사용
1	110콜센터-01	USB	고장	물리적 파기	
2	110콜센터-02	외장형 HDD	용도전환	포맷	전산실-04
3					
4					
5					
6					
7					
8					
9					
10					

확인일자 : 년 월 일

요 청 자 : 소속·직책 성명 : (인)

확 인 자 : 정보보안담당관 성명 : (인)